

Aufsichtsmitteilung

Hinweise zur Umsetzung von DORA
im IKT-Risikomanagement und
IKT-Drittparteienrisikomanagement

Inhaltsverzeichnis

I. Vorwort	4
II. Umsetzungshinweise	7
1. Governance und Organisation	7
1.1 DORA fordert neue Strategie für die digitale operationale Resilienz	8
1.2 Umfassender, aber IKT-spezifischer interner Governance- und Kontrollrahmen	9
1.3 Deutliche Ausweitung der Aufgaben des Leitungsorgans	10
2. Informationsrisiko- und Informationssicherheitsmanagement	11
2.1 Akzentverschiebung von Informationssicherheit zu IKT-Risikomanagement	11
2.2 Größerer Fokus auf Analyse- und Kontrollhandlungen	12
2.3 Stärkung von Schulung und Kommunikation	13
3. IT-Betrieb	14
3.1 Gestärkte Betriebsstabilität	14
3.2 Klassifizierung der IKT-Systeme und -Informationen	15
3.3 Ausweitung auf alle Änderungen an IKT-Systemen	15
3.4 Getrennte Datenhaltung sowie Abgleich der Datensicherung	15
4. IKT-Geschäftsfortführungsmanagement	16
4.1 Veränderte Struktur und Inhalte von Leitlinien und Plänen	17
4.2 Erweiterung verpflichtender Szenarien	18
4.3 Regelmäßige Überprüfung des IKT-Geschäftsfortführungsmanagements	18
4.4 Stärkung von Krisenmanagement und Kommunikation	19
5. IT-Projektmanagement und Anwendungsentwicklung	19
5.1 Vergleichbare Anforderungen im IKT-Projektmanagement	20
5.2 Detailvorgaben zu IKT-System Beschaffung, Entwicklung und Instandhaltung	20
5.3 Wegfall der Wesentlichkeitsgrenze im IKT-Änderungsmanagement	21
6. IKT-Drittparteienrisikomanagement	21
6.1 Abgrenzung zu Auslagerung und Ausgliederung	22
6.2 Ausweitung der Vertragsanforderungen	23
6.3 Neuregelung von Unterauftragsvergaben	24

6.4	Umfangreiche Anforderungen an Risikoanalysen und Due-Diligence	24
6.5	Geänderte Anforderungen an den Ausstieg	25
6.6	Veränderungen an der Governance des IKT-Drittparteienrisikos	26
6.7	Hinweis zu Meldepflichten und Informationsregister	26
7.	Operative Informationssicherheit	26
7.1	Gestärkte Netzwerksicherheit	27
7.2	Verschlüsselung von Daten auch während der Verarbeitung	28
7.3	Zeitnahe Erkennung und Behandlung von Schwachstellen	28
8.	Identitäts- und Rechtemanagement	30
8.1	Explizite Anforderungen an das Identitätsmanagement	30
8.2	Einführung des „need-to-use“ Prinzips	30
III.	Anhang	32
	Mindestvertragsinhalte	32

I. Vorwort

Mit DORA (Digital Operational Resilience Act), der Verordnung (EU) 2022/2554 über die digitale operationale Resilienz im Finanzsektor, hat die Europäische Union eine finanzsektor-übergreifende europäische Regulierung für die Themen digitale operationale Resilienz, IKT-Risiken und Cybersicherheit geschaffen. Die Verordnung ist am 16.01.2023 in Kraft getreten und wird ab dem 17.01.2025 Anwendung finden. Ab diesem Zeitpunkt sind die Anforderungen der DORA von allen Finanzunternehmen zu erfüllen.

Das IKT-Risikomanagement ist das übergreifende Kernelement von DORA. Es soll Finanzunternehmen einen Rahmen bieten, mit dem sie ihre IKT-Risiken systematisch identifizieren, bewerten und steuern können. Die Anforderungen an das IKT-Risikomanagement decken daher dem Grunde nach die Themen ab, die von der BaFin über die aufsichtlichen Anforderungen an die IT (BAIT/VAIT/KAIT/ZAIT) adressiert werden. Gleichwohl unterscheidet sich der methodische Ansatz der Regelwerke, was zu Herausforderungen bei der Umsetzung der DORA-Anforderungen führen kann.

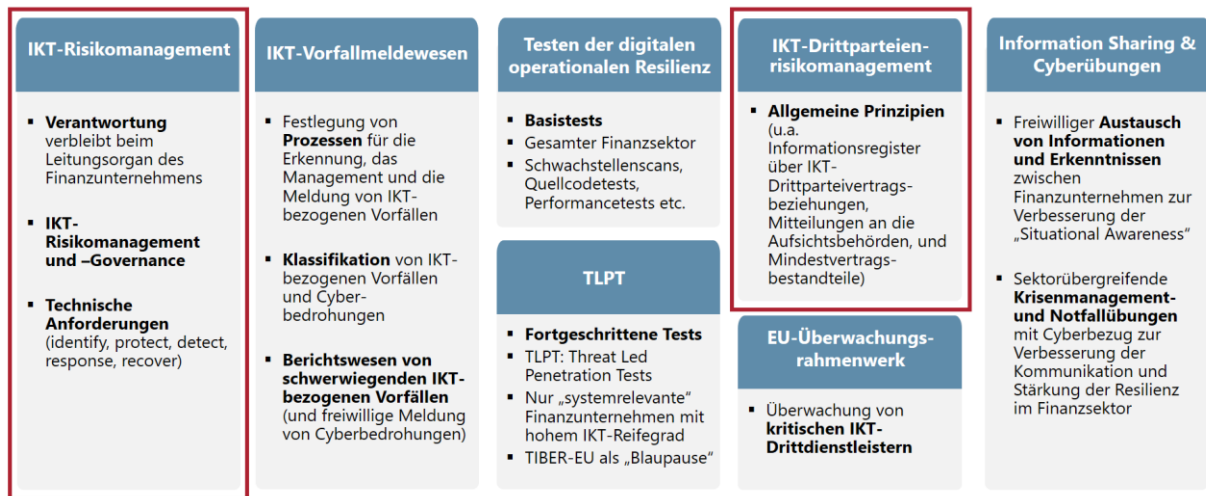
Diese Aufsichtsmitteilung soll eine Unterstützung bei der Umsetzung der DORA-Anforderungen an das IKT-Risikomanagement (Kapitel II) und das IKT-Drittparteienrisikomanagement (Kapitel V Abschnitt I) geben, einschließlich der einschlägigen technischen Regulierungsstandards (RTS)¹. Sie richtet sich insbesondere an diejenigen von der BaFin beaufsichtigten Unternehmen, die unter die Anwendungsbereiche der Bankaufsichtlichen Anforderungen an die IT (BAIT) oder der Versicherungsaufsichtlichen Anforderungen an die IT (VAIT) fallen und künftig u. a. die Anforderungen an das IKT-Risikomanagement gemäß Artt. 5 bis 15 DORA einzuhalten haben. Auch wenn diese Umsetzungshinweise nur die BAIT/VAIT betreffen, sind die hier nicht explizit betrachteten aufsichtlichen Anforderungen an die Kapitalverwaltungsgesellschaften sowie Zahlungs- und E-Geld-Institute (KAIT/ZAIT) in vielen Fällen vergleichbar, sodass sich die Ergebnisse in der Regel übertragen lassen.

Grundlage der Umsetzungshinweise sind die Ergebnisse von sechs in 2023 eingerichteten Arbeitsgruppen, die sich aus Vertreterinnen und Vertretern der Industrie, der Deutschen Bundesbank und der BaFin zusammengesetzt haben. In den Arbeitsgruppen wurden die Anforderungen der DORA an den bereits erwähnten „regulären IKT-Risikomanagementrahmen“ und an die „Schlüsselprinzipien für ein solides Management des IKT-Drittparteienrisikos“ (Artt. 28 - 30 DORA) sowie der dazugehörigen RTS-Entwürfe den Anforderungen der Kapitel 1 bis 10 BAIT und VAIT gegenübergestellt, um wesentliche Änderungen und sich daraus ggf. ergebende Handlungsbedarfe zu identifizieren². Die weiteren Kapitel der DORA wurden in diesem Zusammenhang nicht betrachtet (vgl. Abbildung 1).

¹ Die Level 2-Texte sind immer gemeinsam mit DORA zu betrachten. Die finalen Fassungen werden von der Europäischen Kommission im Amtsblatt der EU veröffentlicht.

² Die Anforderungen an den vereinfachten IKT-Risikomanagementrahmen (Art. 16 DORA) bedürfen einer gesonderten Betrachtung und sind nicht Bestandteil der vorliegenden Analyse.

Abbildung 1: Wesentliche Elemente in DORA



Die Umsetzungshinweise berücksichtigen den zum Zeitpunkt ihrer Veröffentlichung aktuellen Stand der folgenden RTS bzw. des RTS-Entwurfs (Level 2 Rechtstexte):

- COMMISSION DELEGATED REGULATION (EU) 2024/1774 of 13 March 2024 supplementing Regulation (EU) 2022/2554 of the European Parliament and of the Council with regard to regulatory technical standards specifying ICT risk management tools, methods, processes, and policies and the simplified ICT risk management framework (nachfolgend „RTS RMF“)
- COMMISSION DELEGATED REGULATION (EU) 2024/1773 of 13 March 2024 supplementing Regulation (EU) 2022/2554 of the European Parliament and of the Council with regard to regulatory technical standards specifying the detailed content of the policy regarding contractual arrangements on the use of ICT services supporting critical or important functions provided by ICT third-party service providers (nachfolgend „RTS TPPol“)
- Consultation Paper on Regulatory Technical Standards to specify the elements which a financial entity needs to determine and assess when subcontracting ICT services supporting critical or important functions as mandated by Article 30(5) of Regulation (EU) 2022/2554 (nachfolgend „RTS-E SUB“)

Nachträgliche Änderungen im RTS-E SUB können aufgrund des noch nicht abgeschlossenen europäischen Rechtssetzungsprozesses, der mit der Veröffentlichung des Rechtstextes im Amtsblatt der Europäischen Union endet, nicht ausgeschlossen werden.

In den Umsetzungshinweisen wird der Grundsatz der Verhältnismäßigkeit nicht explizit ausgeführt. Dieser ist in Art. 4 DORA für die Kapitel II, III und IV normiert. Damit wird sichergestellt, dass Finanzunternehmen bei der Anwendung von DORA risikobasiert vorgehen können. Die in den einzelnen Artikeln enthaltenen Ausnahmen für Kleinunternehmen werden ebenfalls nicht erläutert.

Ebenso wird auf die Definitionen des Art. 3 DORA in der Analyse nur bei Relevanz Bezug genommen. Eine vergleichbare Liste von definierten Schlüsselbegriffen finden sich weder in den BAIT noch in den VAIT.

Die Umsetzungshinweise stellen keine verbindliche Auslegung der BaFin und auch keine Auslegungen im Rahmen der Fragen- und Antwort-Prozesse (Q&As) der drei Europäischen Aufsichtsbehörden (EBA - European Banking Authority, ESMA - European Securities and Markets Authority und EIOPA - European Insurance and Occupational Pensions Authority) dar.

In der vorliegenden Veröffentlichung hat die BaFin teilweise eigene Übersetzungen der englischsprachigen Entwürfe der Level 2 Rechtstexte verwendet, da diese Basis für die Diskussionen waren. Leitend sind die englischen Originaltexte.

II. Umsetzungshinweise

Die folgenden Umsetzungshinweise für die Implementierung der Anforderungen der DORA werden in die Abschnitte Governance und Organisation, Informationsrisiko- und Informationssicherheitsmanagement, IT-Betrieb, IKT-Geschäftsfortführungsmanagement, IT-Projektmanagement und Anwendungsentwicklung, IKT-Drittparteienrisikomanagement, Operative Informationssicherheit und Identitäts- und Rechtemanagement unterteilt.

Insgesamt ist festzuhalten, dass die Anforderungen der BAIT und VAIT im Wesentlichen in den Anforderungen der DORA an den „regulären IKT-Risikomanagementrahmen“ (Artt. 5 – 15 DORA) und an die „Schlüsselprinzipien für ein solides Management des IKT-Drittparteienrisikos“ (Artt. 28 - 30 DORA) sowie der einschlägigen Level 2-Rechtstexte bzw. deren Entwürfe abgebildet sind. Darüber hinaus enthält DORA aufgrund seines Fokus auf die digitale operationale Resilienz Anforderungen, die sich bisher nicht in den BAIT/VAIT wiederfinden.

Vor dem Hintergrund dieser Einschätzung und der nationalen Umsetzung der DORA durch das Finanzmarktdigitalisierungsgesetz (FinmadiG) beabsichtigt die BaFin, die aufsichtlichen Anforderungen an die IT (BAIT/VAIT/KAIT/ZAIT) aufzuheben. Für Finanzunternehmen, die nicht unter den Anwendungsbereich von DORA fallen ist darauf hinzuweisen, dass Maßnahmen zum angemessenen Umgang mit IT-/ Cyber Risiken im Rahmen der ordnungsgemäßen Geschäftsorganisation in jedem Fall zu treffen sind.

1. Governance und Organisation

In diesem Abschnitt werden die Anforderungen der Artt. 5 und 6 DORA sowie Art. 2 Abs. 2 RTS RMF an die Governance und Organisation des IKT-Risikomanagements in DORA denen der Kapitel IT-Strategie (Kapitel 1) und IT-Governance (Kapitel 2) der BAIT/VAIT gegenübergestellt.

Eine IT-Strategie, wie sie in Kapitel 1 BAIT/VAIT gefordert wird, ist in DORA nicht spezifiziert. DORA enthält dagegen Anforderungen an die Strategie für die digitale operationale Resilienz (folgend DOR-Strategie). Da beide Strategien unterschiedliche Aspekte betrachten, sind die Anforderungen an die DOR-Strategie teilweise neu.

DORA fokussiert auf die Governance und Organisation des IKT-Risikomanagements, d. h. das wirksame und umsichtige Management der IKT-Risiken zur Stärkung der digitalen Resilienz des einzelnen Finanzunternehmens durch einen internen Governance- und Kontrollrahmen. In den BAIT/VAIT stehen demgegenüber die Informationssicherheit und damit einhergehende Governance-Anforderungen im Zentrum der Anforderungen. Die Unterschiede zeigen sich weiter auch in den Inhalten der neuen DOR-Strategie als zentrale Strategie des IKT-Risikomanagementrahmens oder bei den erweiterten Aufgaben des Leitungsorgans.

DORA verweist zudem in Art. 6 Abs. 8 lit. g DORA auf umfangreiche Zusatzanforderungen an das Testen der digitalen operationalen Resilienz (vgl. Kapitel IV, Artt. 24 - 27 DORA). Die Ergebnisse der in den Anforderungen beschriebenen Tests sollen u. a. dazu dienen,

IKT-Risiken zu mitigieren und spezifische IKT-Ziele zu erreichen. Diese zusätzlichen Anforderungen in Kapitel IV sind jedoch nicht Gegenstand dieser Umsetzungshinweise.

1.1 DORA fordert neue Strategie für die digitale operationale Resilienz

DORA führt eine DOR-Strategie neu ein (Art. 6 Abs. 8 DORA). Bei dieser Strategie steht das IKT-Risikomanagement, das auch das IKT-Drittparteienrisikomanagement umfasst, im Fokus. Im Vergleich dazu werden in den BAIT/VAIT Anforderungen an die IT-Strategie gestellt, also der funktionalen, übergreifenden und deutlich breiteren Strategie zur gesamten IT. Auch in den Mindestanforderungen an die Inhalte der beiden Strategien zeigen sich diese Unterschiede, sodass beide Strategien nicht gleichgesetzt werden können. Dabei finden sich bestimmte Inhalte, die die BAIT/VAIT in der IT-Strategie fordern in DORA als Teil der allgemeinen, nicht Strategie bezogenen Anforderungen wieder. Diese sind dann üblicherweise Teil der Anforderungen aus der IKT-Governance. So wird beispielsweise die strategische Entwicklung der IT-Aufbau- und IT-Ablauforganisation (Kapitel 1.2 lit. a BAIT/VAIT) in DORA als Anforderungen an die Organisation der IKT unterhalb der Strategieebene abgebildet (Art. 5 Abs. 2 und Art. 6 Abs. 5 DORA). Aussagen zum IT-Notfallmanagement, wie sie in der IT-Strategie aufgeführt sind, finden sich in der DOR-Strategie nicht explizit wieder. Das Thema IKT-Geschäftsfortführungsmanagement ist aber eine Anforderung des IKT-Risikomanagementrahmens (siehe Abschnitt 4) und gehört zu den Aufgaben des Leitungsorgans (siehe Abschnitt 1.3).

Die Zuordnung gängiger Standards (Kapitel 1.2 lit. b BAIT/VAIT) zu der Umsetzung der Informationssicherheitsanforderungen aus der IT-Strategie findet sich ebenfalls nicht in der DOR-Strategie wieder. Allerdings legt auch DORA, deutlich weniger prominent, die Berücksichtigung von gängigen Standards nahe (Art. 2 Abs. 2 lit. h RTS RMF) und bleibt in seinen Anforderungen und deren Umsetzung durch die Finanzunternehmen ebenfalls standardneutral.

Hinsichtlich der Ziele, Zuständigkeiten und der Einbindung der Informationssicherheit in die Organisation (Kapitel 1.2 lit. c BAIT/VAIT), finden sich auch entsprechende Anforderungen in der DOR-Strategie. Die DOR-Strategie legt hier klare überprüfbare Ziele der Informationssicherheit fest. In Bezug auf die Beziehungen zu IKT-Drittparteienrisiken ist die IKT-Drittparteienrisikostategie gemäß Art. 28 Abs. 2 DORA sowie die optionale Strategie zur Nutzung mehrerer IKT-Anbieter in Art. 6 Abs. 9 DORA zu beachten. Die Einbettung der Informationssicherheit in die Fachbereiche findet sich in DORA hingegen auf der Ebene der jeweiligen Richtlinien für die IKT-Sicherheit wieder.

Die strategische Entwicklung der IT-Architektur (Kapitel 1.2 lit. d BAIT/VAIT) ist vergleichbar mit den Anforderungen der DOR-Strategie in Art. 6 Abs. 8 DORA an die IKT-Referenzarchitektur inkl. Erläuterung etwaiger Änderungen, die für die Erreichung spezifischer Geschäftsziele erforderlich sind. Der Begriff IKT-Referenzarchitektur wird allerdings neu in DORA eingeführt und ist nicht in Art. 3 DORA definiert, sodass in der Abgrenzung ggf. Unschärfen auftreten können.

Hinsichtlich der Form des Dokuments - gesondert oder als Teil der Geschäftsstrategie - trifft DORA im Gegensatz zu den VAIT keine Aussage, es kann aber weiterhin davon ausgegangen werden, dass sich Strategien geeignet kombinieren lassen. In Bezug auf die geeignete

Kommunikation der IT-Strategie (Kapitel 1.5 VAIT) findet sich keine Entsprechung in DORA, allerdings sind hier allgemeine sektorale Governance-Anforderungen zu beachten.

Auch wenn DORA eine IT-Strategie im Sinne der BAIT/VAIT nicht fordert, ist ihr Fortbestand, sowohl als mögliches Bindeglied zwischen Geschäftsstrategie und DOR-Strategie als auch vor dem Hintergrund sektoraler Anforderungen an Strategien in der Geschäftsorganisation durchaus erforderlich und sinnvoll.

1.2 Umfassender, aber IKT-spezifischer interner Governance- und Kontrollrahmen

Der interne IKT-Governancerahmen und -Kontrollrahmen bildet in DORA einen Schwerpunkt. Zu beachten ist dabei, dass die allgemeinen, nicht IKT-spezifischen Governance-Anforderungen aus den sektoralen Regelungen bestehen bleiben. DORA adressiert die Governance des IKT-Risikomanagementrahmens, d. h. das wirksame und umsichtige Management der IKT-Risiken und als dessen Folge die Stärkung der Resilienz des jeweiligen Finanzunternehmens. In den BAIT/VAIT ist der Fokus etwas anders gefasst und liegt insbesondere auf der Informationssicherheit und der damit einhergehenden Governance-Anforderungen.

Auch nach DORA ist eine Risikogesamtsicht erforderlich, da das IKT-Risikomanagement in das allgemeine Risikomanagement der Finanzunternehmen einbezogen ist (Art. 6 Abs. 1 DORA). Wie auch die BAIT/VAIT (vgl. Vorbemerkung Kapitel 4.2 VAIT, Kapitel 4.2 BAIT/VAIT) betont DORA in diesem Zusammenhang die Letzt- sowie die Gesamtverantwortung des Leitungsorgans (Art. 5 Abs. 2 lit. a, d DORA).

Hinsichtlich der Etablierung einer IKT-Risikokontrollfunktion mit Zuständigkeit für das Management und die Überwachung der IKT-Risiken gemäß Art. 6 Abs. 4 DORA (vgl. Abschnitt 2.2) fordert DORA eine angemessene Trennung und Unabhängigkeit zu den verschiedenen Funktionen. Die BAIT/VAIT fordern allgemein die Vermeidung von Interessenkonflikten und unvereinbaren Tätigkeiten in der IT-Aufbau und IT-Ablauforganisation (Kapitel 2.4/ 2.7 BAIT/VAIT). DORA setzt das Modell der drei Verteidigungslinien oder die Verwendung anderer interner Modelle für Risikomanagement und Kontrolle voraus (Art. 6 Abs. 4 DORA).

Neben der IKT-Risikokontrollfunktion sieht DORA in Art. 5 Abs. 3 die Etablierung einer Überwachungsfunktion vor, die Verträge mit IKT-Drittdienstleistern über die Nutzung von IKT-Dienstleistungen zu überwachen hat. Sie ist entweder von einer einzurichtenden Funktion oder von einem Mitglied der Geschäftsleitung wahrzunehmen (s. auch Abschnitt 6.6).

Die in Art. 2 Abs. 2 RTS RMF vorgeschriebenen allgemeinen Anforderungen an die Richtlinien für IKT-Sicherheit, gibt es in den BAIT/VAIT nicht. Allerdings bestehen inhaltlich/kontext-bezogen durchaus Schnittmengen zwischen den einzelnen Richtlinien für IKT-Sicherheit und den BAIT/VAIT. Aufgrund der Unterschiede können Anpassungen seitens der Finanzunternehmen erforderlich werden.

Die Berücksichtigung des Stands der Technik und der zukünftigen Bedrohungslage (Kapitel 2.3/2.4 BAIT/VAIT) sind auch in DORA vorhanden, wenngleich unter anderen Begrifflichkeiten (vgl. u. a. Erwägungsgrund 48 DORA sowie Art. 2 Abs. 2 RTS RMF).

1.3 Deutliche Ausweitung der Aufgaben des Leitungsorgans

DORA weist dem Leitungsorgan durch detaillierte Anforderungen und Aufgaben deutlich mehr Verantwortung zu (Art. 5 Abs. 2 DORA) und stärkt damit dessen Rolle im Kontext der Governance und Organisation. Ähnliche Anforderungen finden sich in den BAIT/VAIT als Aufgabe der Geschäftsleitung an spezifischen Punkten (u. a. IT-Strategie, Regelungen zur IT-Aufbau und IT-Ablauforganisation, Steuerung IT-Betrieb, IRM, Informationssicherheitsleitlinie, ISM, Untersuchung Informationssicherheitsvorfälle, IT-Projektmanagement), sind aber weniger umfangreich.

Art. 5 Abs. 4 DORA fordert von den Mitgliedern des Leitungsorgans ausreichende Kenntnisse und Fähigkeiten zu den zu managenden IKT-Risiken, die aktiv auf dem neuesten Stand zu halten sind. Hierzu findet sich keine explizite Entsprechung in den BAIT/VAIT; die Rundschreiben fordern eher allgemein eine angemessene quantitative und qualitative Ressourcenausstattung.

Dem Leitungsorgan des Finanzunternehmens obliegt in vielen Fällen die Definition, Genehmigung, Überwachung und Verantwortung zu Vorkehrungen im Zusammenhang mit dem IKT-Risikomanagementrahmen (vgl. insbesondere Art. 6 Abs. 1 DORA):

- Gemäß Art. 5 Abs. 2 lit b DORA sind Leitlinien zur Aufrechterhaltung von hohen Standards in Bezug auf die vier Schutzziele DORAs einzuführen, dazu zählen die Informationssicherheitsleitlinie des Art. 9 Abs. 4 lit. a DORA, die Leitlinie zum IKT-Geschäftsfortführungsmanagement und zum IKT-Drittparteienrisikomanagement.
- Die im RTS RMF aufgeführten Richtlinien für IKT-Sicherheit sind ebenfalls durch das Leitungsorgan zu genehmigen (Art. 2 Abs. 2 lit. b RTS RMF). Eine vergleichbare Anforderung, auf Ebene von Richtlinien, kennen die BAIT/VAIT nicht.
- Die in Kapitel 2.4/2.7 BAIT/VAIT vorgeschriebene Vermeidung von Interessenkonflikten durch geeignete organisatorische Maßnahmen ist auch in DORA Gegenstand der Anforderungen. Zwar ist die „Vermeidung von Interessenkonflikten“ in DORA nicht explizit genannt, sie ergibt sich aber aus den Governance-Anforderungen und wird weiter insbesondere in Art. 2 Abs. 2 lit. g RTS RMF aufgeführt. Die Aufgabe zur Festlegung von klaren Aufgaben und Verantwortlichkeiten für alle IKT-bezogenen Funktionen fällt gemäß Art. 5 Abs. 2 lit c DORA dem Leitungsorgan zu.
- Die Umsetzung der IKT-Geschäftsfortführungsleitlinie und der IKT-Reaktions- und Wiederherstellungspläne sind regelmäßig zu genehmigen, zu überwachen und zu überprüfen.
- Wie auch die BAIT/VAIT schreibt DORA eine angemessene Ressourcenausstattung vor, um den Anforderungen an die digitale operationale Resilienz gerecht zu werden; hiervon umfasst sind auch die IKT-Kompetenzen für alle Mitarbeiter. Dies sicherzustellen obliegt der Verantwortung des Leitungsorgans (Art. 5 Abs. 2 lit. g DORA).
- Die internen IKT-Revisionspläne der IKT-Revision und wesentlicher Änderungen an diesen sind regelmäßig zu genehmigen und zu überprüfen.

2. Informationsrisiko- und Informationssicherheitsmanagement

In diesem Abschnitt werden die Vorgaben an das Informationsrisiko- und Informations-sicherheitsmanagement sowie den IKT-Risikomanagementrahmen der Artt. 3, 5, 6, 8, 13, 14, 45, 49 DORA und der Artt. 3 - 5 und 27 RTS RMF denen der Kapitel Informationsrisiko-management und Informationssicherheitsmanagement der BAIT/VAIT gegenübergestellt.

Um das Ziel der digitalen operationalen Resilienz zu erreichen, ist das IKT-Risikomanagement für DORA von zentraler Bedeutung. Im Vergleich zu den BAIT/VAIT setzt DORA einen deutlich stärkeren Schwerpunkt auf das IKT-Risikomanagement gegenüber der Informationssicherheit. Dies zeigt sich auch in der Einführung der IKT-Risikokontrollfunktion, die die „Zuständigkeit für das Management und die Überwachung des IKT-Risikos“ übernehmen soll. Sie ähnelt dem aus BAIT/VAIT bekannten Informationssicherheitsbeauftragten (ISB) - der jedoch stärker für die Belange der Informationssicherheit zuständig ist.

Weiterhin werden neue Prüfungs- und Analyseanforderungen zu IKT-Risiken, neuen Technologien, Altsystemen, Vorfällen und Tests eingeführt sowie damit verbundene Berichtspflichten, auch gegenüber der Aufsicht. So ist u. a. eine mindestens jährliche oder anlassbezogene Überprüfung des IKT-Risikomanagementrahmens vorgesehen, die in Form eines Berichtes von der Aufsicht angefordert werden kann. Weiterhin betont DORA Schulungspflichten sowie Kommunikationsstrategien vor dem Hintergrund der digitalen operationalen Resilienz.

2.1 Akzentverschiebung von Informationssicherheit zu IKT-Risikomanagement

Eine grundsätzliche Akzentverschiebung erfolgt durch die deutlich stärkere Betonung des IKT-Risikomanagements gegenüber der Informationssicherheit. Gemäß DORA ist das IKT-Risikomanagement die Grundlage zur Sicherstellung der digitalen operationalen Resilienz, wozu Maßnahmen der Informationssicherheit herangezogen werden. In den BAIT/VAIT liegt der Fokus auf den Informationssicherheitsmaßnahmen, die Risikobetrachtung folgt darauf. Die in der Praxis tatsächlich notwendigen Maßnahmen dürften sich allerdings in beiden Betrachtungen nicht wesentlich unterscheiden. Eine stärkere Orientierung am IKT-Risiko auf Basis dieser Akzentverschiebung, mit einer entsprechenden Priorisierung in der Umsetzung, ist aber durchaus denkbar.

Zudem sieht DORA kein Verbot der Auslagerung³ von IKT-Risikomanagementfunktionen vor. Art. 6 Abs. 10 DORA weist explizit auf die Auslagerbarkeit der „Überprüfung der Einhaltung der Anforderungen für das IKT-Risikomanagement“ hin. Im Falle einer Auslagerung sind allerdings weiterhin sektorspezifische Anforderungen⁴ an die Auslagerbarkeit zu beachten. Im konkreten Auslagerungsfall können diese sektoralen Regelungen durchaus Voraussetzungen, Bedingungen oder Grenzen für eine solche Auslagerung definieren. Auch bleibt das Finanzunternehmen für die Sicherstellung des IKT-Risikomanagements uneingeschränkt verantwortlich.

³ Ausgliederungen sind dabei mit eingeschlossen.

⁴ Beispielsweise Rundschreiben 05/2023 (BA) - Mindestanforderungen an das Risikomanagement (MaRisk), Rundschreiben 2/2017 (VA) - Mindestanforderungen an die Geschäftsorganisation von Versicherungsunternehmen (MaGo) oder Leitlinien der Europäischen Aufsichtsbehörden zu Auslagerungen.

Die Festlegung eines Informationsverbunds gemäß Kapitel 3.3/3.4 BAIT/VAIT und das Verfahren zur Schutzbedarfsfeststellung gemäß Kapitel 3.4/3.5 BAIT/VAIT werden durch ein IKT-Assetmanagement und die Klassifizierung dieser Assets ersetzt. DORA stellt dabei auf die Ermittlung oder Identifizierung und Klassifizierung von IKT-gestützten Unternehmensfunktionen ab sowie auf Informationsassets und IKT-Assets, die diese Funktionen unterstützen (Art. 8 Abs. 1 DORA sowie Art. 4 und 5 RTS RMF). Dabei sind kritische Assets sowie Abhängigkeiten zu IKT-Drittdienstleistern und Risiken aus Cyberbedrohungen und IKT-Schwachstellen zu identifizieren. Die Dokumentation soll in Inventaren erfolgen. Durch die Verpflichtung, die Konfiguration von Informationsassets und IKT-Assets und die Verbindungen/Interdependenzen zwischen den Assets zu erfassen, entsteht auch eine inhaltliche Nähe zu einer Configuration Management Database (CMDB). Wenn die Abdeckung der DORA-Besonderheiten sichergestellt ist, können die Verfahren zur Festlegung des Informationsverbunds in Verbindung mit der Anforderung zur Verwaltung von Komponenten der IT-Systeme aus dem IT-Betrieb und der Schutzbedarfsfeststellung zur Umsetzung herangezogen werden; andere Lösungsmöglichkeiten sind aber auch denkbar.

2.2 Größerer Fokus auf Analyse- und Kontrollhandlungen

DORA führt in Art. 6 Abs. 4 DORA eine IKT-Risikokontrollfunktion ein, die dem in Kapitel 4.4/4.5 BAIT/VAIT vorgeschriebenen Informationssicherheitsbeauftragten (ISB) in Stellung und Unabhängigkeit sehr ähnelt, aber nicht identisch ausgestaltet ist. So soll der ISB die Verantwortung für die „Wahrnehmung aller Belange der Informationssicherheit“ haben, während die Kontrollfunktion die „Zuständigkeit für das Management und die Überwachung des IKT-Risikos“ übernehmen soll. Die Weiterentwicklung des ISB hin zur IKT-Risikokontrollfunktion erscheint sinnvoll, um dieser Veränderung Rechnung zu tragen. Falls eine Übernahme der Aufgaben der einzurichtenden IKT-Risikokontrollfunktion durch den ISB angestrebt wird, sollte sichergestellt sein, dass dieser auch die Aufgaben des IKT-Risikomanagements wahrnimmt. Die weniger detaillierte Ausführung der konkreten Aufgaben der IKT-Risikokontrollfunktion eröffnet hier auch Handlungsspielräume für einen veränderten Aufgabenzuschnitt.

DORA schreibt umfangreiche neue Prüfungs- und Analyseanforderungen zu IKT-Risiken, neuen Technologien, Altsystemen, Vorfällen und Tests vor sowie damit verbundene Berichtspflichten, teilweise auch gegenüber der Aufsicht. Dazu zählen insbesondere:

- Eine Überprüfung des IKT-Risikomanagementrahmens nach Art. 6 Abs. 5 DORA soll mindestens einmal jährlich oder anlassbezogen bei Auftreten schwerwiegender IKT-bezogener Vorfälle bzw. bei Feststellungen aus Tests (Kapitel IV DORA) oder Prüfungen durchgeführt werden. Darauf baut eine kontinuierliche Verbesserung des IKT-Risikomanagementrahmens auf. Die Aufsicht kann eine Überprüfung verlangen und einen Bericht zur Überprüfung anfragen (Titel II, Kapitel V RTS RMF).
- Nach schwerwiegenden IKT-bezogenen Vorfällen mit Störung von Haupttätigkeiten sind die Störungsursache zu untersuchen und erforderliche Verbesserungen zu identifizieren (Art. 13 Abs. 2 DORA). Dabei ist auch auf die Reaktionsgeschwindigkeit, etwaige forensische Analysen, die Eskalation und die Kommunikation einzugehen.
- Die spezifischen Risiken für alle IKT-Altsysteme sind mindestens jährlich zu bewerten (Art. 8 Abs. 7 i. V. m. Art. 3 Nr. 3 DORA). Diese Risikobewertung muss „in jedem Fall

vor und nach Anschluss von Technologien, Anwendungen oder Systemen“ durchgeführt werden.

- Leitende IKT-Mitarbeiter sollen dem Leitungsorgan mindestens jährlich Bericht über Feststellungen aus Vorfällen und Tests erstatten und ihre Empfehlungen dazu abgeben (Art. 13 Abs. 5 DORA). Dabei geht es insbesondere um Cyberangriffe und andere notfallrelevante Vorfälle, sowie um Threat-led Penetration Testing (TLPT) oder aufsichtliche Überprüfungen.

Es ist anzunehmen, dass zur Umsetzung dieser Analyse- und Berichtspflichten neue Prozesse geschaffen oder bestehende angepasst werden müssen. Neben dem retrospektiven Blick auf IKT-bezogene Vorfälle und die Leistungsfähigkeit des IKT-Risikomanagementrahmens in der Vergangenheit sollen auch neue technologische Entwicklungen, u. a. mit Blick auf Cyberangriffe, überwacht werden (Art. 13 Abs. 7 DORA und Art. 3 Abs. 1 lit. e RTS RMF). Dabei sollen Auswirkungen untersucht werden, die durch den Einsatz neuer Technologien für die IKT-Sicherheit und die digitale operationale Resilienz entstehen. Ein Schwerpunkt liegt dabei auf der Beobachtung von „neusten“ IKT-Risikomanagementprozessen zur wirksamen Abwehr von bestehenden und neuen Formen von Cyberangriffen.

2.3 Stärkung von Schulung und Kommunikation

DORA betont Schulungspflichten deutlich stärker als BAIT/VAIT. So haben Finanzunternehmen für ihre Mitarbeiter und die Geschäftsleitung Programme zur Sensibilisierung für IKT-Sicherheit und Schulungen zur digitalen operationalen Resilienz zu entwickeln (Art. 13 Abs. 6 DORA). Darüber hinaus haben die Mitglieder des Leitungsorgans ihre Kenntnisse und Fähigkeiten zu IKT-Risiken auf dem neusten Stand zu halten, auch durch spezielle Schulungen (Art. 5 Abs. 4 DORA). Generell sollen die Schulungen auf den Aufgabenbereich abgestimmt sein und ggf. auch eingesetzte IKT-Drittdienstleister abdecken.

Als Teil des IKT-Risikomanagementrahmens müssen Finanzunternehmen Kommunikationsstrategien⁵, -leitlinien und -pläne zumindest für schwerwiegende IKT-Vorfälle und Schwachstellen einrichten, um eine Offenlegung von Vorfällen und Schwachstellen verantwortungsbewusst zu ermöglichen (Art. 14 DORA). Dabei soll zwischen den unterschiedlichen Adressaten - darunter explizit auch die Öffentlichkeit - unterschieden werden. Finanzunternehmen haben mindestens eine Person mit der Umsetzung der Kommunikationsstrategie für IKT-bezogene Vorfälle zu beauftragen, die zu diesem Zweck die entsprechende Aufgabe gegenüber der Öffentlichkeit und den Medien wahrnimmt (Art. 14 Abs. 3 DORA).

Finanzunternehmen können freiwillig an einem Informationsaustausch zu Cyberbedrohungen und -informationen innerhalb vertrauenswürdiger Gemeinschaften teilnehmen (Art. 45 Abs. 1 DORA). Eine Teilnahme an einem solchen Informationsaustausch muss gegenüber der Aufsichtsbehörde gemeldet werden, ebenso ist die Beendigung der Zusammenarbeit mitzu-

⁵ In der deutschen Sprachversion DORAs ist die Übersetzung aus dem Englischen in Art. 14 Abs. 2 DORA u. E. fehlerhaft: Der englische Begriff „communication policies“ sollte mit „Kommunikationsleitlinien“ anstelle von „Kommunikationsstrategien“ übersetzt werden.

teilen (Art. 45 Abs. 3 DORA). Gemäß Art. 49 Abs. 1 DORA können Aufsichtsbehörden Krisenmanagement- und Notfallübungen anbieten, um eine koordinierte Reaktion zu üben und Kommunikationskanäle zu entwickeln.

3. IT-Betrieb

In diesem Abschnitt werden die Vorgaben der Artt. 7, 8, 9 und 12 DORA sowie der Artt. 4, 5, 8, 9 und 17 RTS RMF an den Betrieb von IT-Systemen dem Kapitel 8 IT-Betrieb der BAIT/VAIT gegenübergestellt.

Dem IT-Betrieb kommt im Rahmen der Stärkung der digitalen operationalen Resilienz eine gesteigerte Bedeutung zu. Anforderungen an aktuelle, zuverlässige sowie technologisch resiliente IKT-Systeme sind in DORA stärker als bisher enthalten. Auch die detaillierte Übersicht über die IKT-Systeme wird enger mit den Geschäftsfunktionen verzahnt. Daher werden die IKT-Systeme, -Informationen und deren Wechselwirkungen untereinander nun gemeinsam identifiziert, klassifiziert und in Form eines Inventars geführt. Darüber hinaus sind mehr Änderungen als bisher an diesen Systemen im Rahmen des Änderungsmanagements zu betrachten. Die Sicherung und Wiederherstellung von Daten werden um Anforderungen wie getrennte Systeme oder Mehrfachprüfungen nach einer Wiederherstellung ergänzt.

3.1 Gestärkte Betriebsstabilität

Im Rahmen der digitalen operationalen Resilienz liegt ein weiterer Schwerpunkt auf der Betriebsstabilität und Aktualisierung von IKT-Systemen. Dies betont Art. 7 DORA und verschärft damit die bestehenden Anforderungen der BAIT/VAIT. So fordert Art. 7 DORA „stets auf dem neusten Stand zu haltende IKT-Systeme“ und geht damit über die bisherige Regulierung hinaus, welche vorrangig Aktualisierungen der IT-Systeme verlangte (Kapitel 8.3 BAIT/VAIT). Weiterhin werden die Anforderungen an die Zuverlässigkeit (Art. 7 lit. b DORA) sowie die technologische Resilienz (Art. 7 lit. d DORA) der IKT-Systeme erweitert. IKT-Systeme müssen auch in angespannten Marktphasen eine angemessene Informationsverarbeitung sicherstellen. Diese Anforderungen wurden bisher in BAIT/VAIT nicht so explizit herausgestellt.

Auch das aus Kapitel 8.8 BAIT/VAIT bekannte Kapazitätsmanagement wird durch Art. 7 lit. c DORA i. V. m. Art. 9 RTS RMF ausgebaut. So ist dieses beispielsweise stärker als bisher zu dokumentieren. Zudem sind Maßnahmen zur Ressourcenoptimierung zu bestimmen sowie Ressourcenengpässe vor ihrem Eintritt durch geeignete Überwachung zu analysieren und abzuwenden. Auch redundante IKT-Kapazitäten mit Ressourcen, Fähigkeiten und Funktionen, die für die Deckung des Geschäftsbedarfs ausreichend und angemessen sind, werden in Art. 12 Abs. 4 DORA gefordert.

Im Zuge der Stärkung der Resilienz kommt auch der Überprüfung bestehender IKT-Alt-systemen eine größere Bedeutung als bisher zu. Diese waren auch bisher bereits zu steuern (Kapitel 8.3 BAIT/VAIT), müssen aber künftig einmal jährlich sowie bei jeder Änderung des IKT-Risikos explizit untersucht und hinsichtlich des von ihnen ausgehenden IKT-Risikos bewertet werden (Art. 8 Abs. 7 DORA).

3.2 Klassifizierung der IKT-Systeme und -Informationen

Wie in Abschnitt 2.1 beschrieben, müssen IKT-Systeme und -Informationen, die in Geschäftsfunktionen verwendet werden, identifiziert und klassifiziert werden. Dabei sind auch die Wechselwirkungen der IKT-Assets untereinander und Verbindungen zu den Geschäftsfunktionen zu berücksichtigen (Art. 8 Abs. 1 DORA i. V. m. Art. 4 RTS RMF). Dieses Verfahren zieht die bisherige getrennte Festlegung eines Informationsverbunds und die Auflistung der Komponenten der IT-Systeme zusammen (Kapitel 3 und 8 BAIT/VAIT) und erzeugt so ein ganzheitliches Bild über die IKT-Systeme und -Informationen, welches bisher nicht in dieser Form vorlag.

3.3 Ausweitung auf alle Änderungen an IKT-Systemen

Der bereits aus Kapitel 8.4 und 8.5 BAIT/VAIT bekannte risikoorientierte Ansatz des Änderungsmanagements wird in DORA in erweiterter Form gefordert (Art. 9 Abs. 4 lit. e, f DORA i. V. m. Art. 17 RTS RMF). Die bisherige Betrachtung beschränkte sich auf wesentliche Änderungen, diese Einschränkung ist künftig nicht mehr vorgesehen. Gemäß Art. 9 Abs. 4 lit. e DORA sind künftig alle Änderungen an IKT-Systemen im Rahmen des IKT-Änderungsmanagements auf kontrollierte Weise zu erfassen, zu testen, zu bewerten, zu genehmigen, zu implementieren und zu überprüfen. Damit ist eine deutlich größere Menge an Änderungen als bisher zu betrachten.

Weiterhin macht Art. 17 RTS RMF Vorgaben zu den Mindestinhalten des IKT-Änderungsmanagementverfahrens, wie u. a. Prüfpflichten, Testen dieser Änderungen, Auswirkungsanalysen oder Fallback-Lösungen und geht damit über die bisherigen Anforderungen hinaus. Weitere Informationen dazu folgen im Abschnitt 5.3 aus Sicht der Projektmanagements.

3.4 Getrennte Datenhaltung sowie Abgleich der Datensicherung

Das Thema Datensicherung sollte grundsätzlich bereits aus dem in Kapitel 8.7 BAIT/VAIT geforderten Datensicherungskonzept bekannt sein. Gemäß Art. 12 DORA ist eine Richtlinie über Verfahren zum Backup sowie Verfahren und Methoden zur Wiedergewinnung und Wiederherstellung zu definieren. Damit werden die bestehenden Anforderungen der BAIT/VAIT erweitert, welche vorrangig ein Datensicherungskonzept forderten.

DORA enthält vergleichbare konzeptionelle Anforderungen zum bekannten Datensicherungskonzept (Art. 12 Abs. 1 lit. a DORA). So sind Richtlinien und Verfahren zu entwickeln und zu dokumentieren, die auf minimale Ausfallzeiten bei der Wiederherstellung von IKT-Systemen und Daten eingehen sowie begrenzte Störungen und Verluste sicherstellen.

Darüber hinaus ist bei der Durchführung der Datensicherung und Wiederherstellung gemäß Art. 12 Abs. 2 DORA sicherzustellen, dass die Sicherheit der Netzwerk- und Informationssysteme sowie die Verfügbarkeit, Authentizität, Integrität oder Vertraulichkeit von Daten nicht gefährdet wird. Diese Anforderung ist in den BAIT/VAIT, insbesondere in Bezug auf die Sicherheit der Systeme (Kapitel 8.7 BAIT/VAIT), nicht enthalten.

Die Verfahren zur Sicherung sowie Wiederherstellung sind gemäß Art. 12 Abs. 2 DORA sowie 8.7 BAIT/VAIT regelmäßig zu testen. Zu beachten ist bei der Wiederherstellung von Daten, dass Art. 12 Abs. 3 DORA IKT-Systeme vorschreibt, die vom Quellsystem physisch und logisch getrennt sind. In BAIT/VAIT ist dies nur als ein mögliches Erfordernis aufgeführt. DORA übersteigt daher in Bezug auf die Datenhaltung die bisherigen Vorgaben aus BAIT/VAIT.

Zudem führt Art. 12 Abs. 7 DORA bei der Datenwiederherstellung nach IKT-bezogenen Vorfällen Prüfungen von Daten ein, welche auch Mehrfachprüfungen und Abgleiche beinhalten, um die größtmögliche Datenintegrität sicherzustellen. Eine solche Form des Datenabgleichs bzw. der Prüfung ist in den BAIT/VAIT nicht vorgesehen.

Die Meldung von ungeplanten Abweichungen vom Regelbetrieb (Störungen) ist bereits aus Kapitel 8.6 BAIT/VAIT bekannt. DORA verwendet für diese Störungen den Begriff eines „errors“ bzw. Fehlers (Art. 8 Abs. 2 lit. c RTS RMF). Diese Fehler sind, vergleichbar zu den Störungen, weiterhin mittels geeigneter Verfahren und Protokolle zu betrachten.

Darüber hinaus verweist DORA innerhalb des IKT-Risikomanagements auf umfangreiche Zusatzanforderungen zur Behandlung, Klassifizierung und Berichterstattung von IKT-bezogenen Vorfällen (vgl. Kapitel III, Artt. 17 - 23 DORA) und das Testen (vgl. Kapitel IV, Artt. 24 - 27 DORA). Die Kapitel III und IV DORA sind jedoch nicht Gegenstand dieser Umsetzungshinweise.

4. IKT-Geschäftsfortführungsmanagement

In diesem Abschnitt werden die relevanten Vorgaben der Artt. 11, 12 und 14 DORA sowie der Artt. 24 bis 26 RTS RMF an das IKT-Geschäftsfortführungsmanagement respektive Reaktion und Wiederherstellung (folgend IKT-Geschäftsfortführungsmanagement) den Kapiteln IT-Betrieb und (IT-)Notfallmanagement der BAIT/VAIT (jeweils Kapitel 10) gegenübergestellt.

Zusammenfassend ist festzuhalten, dass Art. 11 DORA als auch die Artt. 24 bis 26 RTS RMF weiter gefasst sind, als die in Kapitel 10 BAIT/VAIT aufgeführten Anforderungen. Maßgebliche Unterschiede ergeben sich aus veränderten Inhalten als auch Struktur der einschlägigen Leitlinien und Pläne, in deren Mittelpunkt die IKT-Geschäftsfortführungsleitlinie steht.

Darüber hinaus hat sich die Anzahl der zu berücksichtigenden Szenarien im Vergleich zu den BAIT/VAIT erhöht: Beispielsweise sind Auswirkungen des Klimawandels und Insider-Angriffe insbesondere bei der Entwicklung der IKT-Reaktions- und Wiederherstellungspläne einzubeziehen.

Weitere Änderungen ergeben sich bei der Überprüfung des IKT-Geschäftsfortführungsmanagements, das in DORA dem Leitungsorgan hinsichtlich der IKT-Geschäftsfortführungsleitlinie als auch der IKT-Reaktions- und Wiederherstellungspläne obliegt und derart in den BAIT/VAIT nicht spezifiziert ist. Bei der Überprüfung als auch dem Testen der verschiedenen Pläne des IKT-Geschäftsfortführungsmanagements sieht DORA regelmäßige beziehungsweise mindestens jährliche Intervalle vor und unterscheidet sich damit von den BAIT/VAIT. Überdies schärft DORA durch die Etablierung einer Krisenmanagementfunktion und insgesamt einem stärkeren Fokus auf die (Krisen-)Kommunikation diese Anforderungen deutlich gegenüber der BAIT/VAIT.

Darüber hinaus sieht DORA auf Anfrage eine Meldung an die zuständigen Behörden über die geschätzten aggregierten jährlichen Kosten und Verluste, die durch schwerwiegende IKT-bezogene Vorfälle verursacht wurden, vor. Details dazu spezifiziert eine Leitlinie. Diese Meldung ist nicht Teil dieser Umsetzungshinweise.

4.1 Veränderte Struktur und Inhalte von Leitlinien und Plänen

Als zentrales Element im IKT-Geschäftsfortführungsmanagement wird gemäß Art. 11 Abs. 1 DORA eine IKT-Geschäftsfortführungsleitlinie neu eingeführt, die fester Bestandteil der allgemeinen Geschäftsfortführungsleitlinie ist und auf den Identifizierungsanforderungen des Art. 8 DORA fußt (siehe Abschnitt 2.2). Der Begriff IKT-Geschäftsfortführungsleitlinie findet sich in den BAIT/VAIT nicht wieder. BAIT/VAIT verwenden im Kapitel IT-Betrieb bzw. in der Einleitung zum Kapitel IT-Notfallmanagement (BAIT) den Begriff Geschäftsfortführungspläne.

Die Ziele der IKT-Geschäftsfortführungsleitlinie sind in Art. 11 Abs. 2 DORA aufgeführt. Neben dem Erfordernis ihrer Dokumentation sind Inhalte dieser Leitlinie insbesondere:

- die angemessene Reaktion auf alle IKT-bezogenen Vorfälle zur Schadenbegrenzung, verbunden mit der Wiederaufnahme von Tätigkeiten und dem Vorrang von Wiederherstellungsmaßnahmen;
- die Aktivierung von Plänen mit Eindämmungsmaßnahmen, Prozessen und Technologien bei IKT-bezogenen Vorfällen sowie
- die zwingende Einschätzung der vorläufigen Auswirkungen, Schäden und Verlusten (wie ggf. bereits im Rahmen der PSD2-Meldungen zu schwerwiegenden Betriebs- und Sicherheitsvorfällen umgesetzt);
- die Festlegung von Kommunikations- und Krisenmanagementmaßnahmen.

Die Komponenten der IKT-Geschäftsfortführungsleitlinie sind in Art. 24 RTS RMF ausführlich dargestellt. Eine Business Impact Analyse (BIA) und Risikoanalyse sind für schwerwiegende Betriebsstörungen bei der Durchführung der allgemeinen Geschäftsfortführungsleitlinie zu berücksichtigen, wobei die Risikoanalyse in DORA Teil der BIA ist (Art. 11 Abs. 5 DORA bzw. Kapitel 10.3, 10.4 VAIT). Dabei sind in der Geschäftsfortführungsleitlinie die entsprechenden Rahmenbedingungen aufzuführen.

Bei der Festlegung von Wiederherstellungszeit und Wiederherstellungspunkten für jede Funktion berücksichtigen die Finanzunternehmen neben der Eigenschaft kritische oder wichtige Funktion auch die potentiellen Gesamtauswirkungen auf die Markteffizienz (Art. 12 Abs. 6 DORA bzw. Kapitel 10.3/ 10.5 BAIT/VAIT). Letzteres wird in DORA eingeführt.

Die in den Kapiteln 8.7, 10.1/ 8.7 BAIT/VAIT aufgeführten Geschäftsfortführungspläne, finden sich so zwar nicht in DORA wieder. Mit den IKT-Geschäftsfortführungsplänen (Art. 11 Abs. 4 DORA) enthält DORA allerdings ein vergleichbares Konstrukt. Diese Pläne sind regelmäßig zu pflegen (Art. 11 Abs. 4 DORA) und zu testen (siehe Abschnitt 4.3). Art. 25 RTS RMF schreibt weitergehende Anforderungen an das Testen der IKT-Geschäftsfortführungspläne vor. Demnach sind bei der Erstellung, der Pflege und dem Testen der Geschäftsfortführungspläne u. a. Auslagerungen und vertragliche Vereinbarungen an IKT-Drittdienstleister insbesondere in Bezug auf kritische und wichtige Funktionen einzubeziehen (Art. 25

Abs. 2 RTS RMF). Die Ergebnisse der o. g. BIA als auch der IKT-Risikobeurteilung sind dabei zu berücksichtigen (Art. 3 Abs. 1 lit. b DORA).

Der Begriff „IT-Notfallpläne“ betreffend die Wiederanlauf-, Notbetriebs- und Wiederherstellungspläne (vgl. insbesondere Kapitel 10.3/10.5 BAIT/VAIT) findet sich in DORA nicht wieder. DORA führt auf dieser Ebene IKT-Reaktions- und Wiederherstellungspläne ein (Art. 11 Abs. 3 DORA). Diese Pläne sind in Art. 26 RTS RMF weitergehend spezifiziert.

Wie auch die IKT-Geschäftsfortführungspläne sind die IKT-Reaktions- und Wiederherstellungspläne zu testen (Art. 11 Abs. 6 lit. a DORA, siehe Abschnitt 4.3). Ebenso sieht Art. 11 Abs. 6 lit. b DORA das Testen der Krisenkommunikationspläne vor. Eine solche Anforderung findet sich in BAIT/VAIT nicht wieder. Die Testergebnisse sind unter DORA schriftlich zu dokumentieren und alle bei den Tests festgestellten Mängel sind zu analysieren, zu beheben und an das Leitungsorgan zu berichten.

4.2 Erweiterung verpflichtender Szenarien

Die verpflichtende Berücksichtigung von spezifischen Szenarien ist in DORA bei der Erstellung der IKT-Reaktions- und Wiederherstellungspläne aufgeführt (Art. 26 Abs. 2 RTS RMF) und mit den Komponenten der IKT-Geschäftsfortführungsleitlinie sowie mit der allgemeinen Geschäftsfortführungsleitlinie verknüpft (Art. 24 Abs. 1 lit. b Ziffer i Abs. 1 und Art. 25 Abs. 2 lit. e RTS RMF). Weiter unterscheidet sich die Anzahl der zu berücksichtigenden Szenarien gegenüber BAIT/VAIT. Folgende Szenarien kommen neu hinzu:

- Auswirkungen des Klimawandels und von Ereignissen, die mit der Verschlechterung der Umwelt zusammenhängen, Naturkatastrophen, Pandemien und physische Angriffe, einschließlich Einbrüche und terroristische Angriffe;
- Insider-Angriffe;
- politische und soziale Instabilität, gegebenenfalls auch in dem Land, in dem der IKT-Drittdienstleister seine Dienstleistungen erbringt und an dem Ort, an dem die Daten gespeichert und verarbeitet werden sowie
- großflächige Stromausfälle.

4.3 Regelmäßige Überprüfung des IKT-Geschäftsfortführungsmanagements

Das (IT-)Notfallkonzept ist laut BAIT regelmäßig auf Wirksamkeit und Angemessenheit bzw. laut VAIT regelmäßig - inkl. der IT-Notfallpläne - auf Aktualität zu überprüfen; eine Aktualisierung des IT-Notfallkonzepts forderte die VAIT anlassbezogen. In DORA obliegt dem Leitungsorgan beziehungsweise dem Finanzunternehmen die Genehmigung und regelmäßige Überwachung der IKT-Geschäftsfortführungsleitlinie und der IKT-Reaktions- und Wiederherstellungspläne (Art. 5 Abs. 2 lit. e DORA und Art. 11 Abs. 6 DORA betreffend die Überprüfung). Hier sind allerdings die Unterschiede bei den Begrifflichkeiten zu beachten, sodass eine direkte Gegenüberstellung nicht ohne weiteres möglich ist.

Für die mindestens jährliche Überprüfung der Wirksamkeit und Angemessenheit aller relevanten Szenarien und Aktivitäten in den BAIT gibt es keine direkte Entsprechung in DORA.

Die in Art. 11 Abs. 6 lit. a DORA vorgesehenen regelmäßigen Tests der IKT-Geschäftsfortführungspläne finden keine direkte Entsprechung in BAIT/VAIT. Die ebenfalls geforderten Tests der IKT-Reaktions- und Wiederherstellungspläne, sind vergleichbar mit den Anforderungen an jährliche (BAIT) bzw. regelmäßige (VAIT) Tests der Wirksamkeit der IT-Notfallpläne, da sie eine Schnittmenge mit diesen IT-Notfallplänen aufweisen. Allerdings sind diese Tests mindestens jährlich durchzuführen sowie im Falle jeglicher wesentlichen Änderungen an IKT-Systemen, die kritische oder wichtige Funktionen unterstützen (Art. 11 Abs. 6 lit. a DORA).

Wie schon in Abschnitt 2.2 erörtert ist der IKT-Risikomanagementrahmen, zu dem das IKT-Geschäftsfortführungsmanagement gehört, mindestens jährlich o. ä. zu überprüfen.

4.4 Stärkung von Krisenmanagement und Kommunikation

Art. 11 Abs. 7 DORA sieht die Etablierung einer Krisenmanagementfunktion vor. Diese soll bei der Aktivierung von IKT-Geschäftsfortführungsplänen oder IKT-Reaktions- und Wiederherstellungsplänen unter anderem klare Verfahren für die Abwicklung interner und externer Krisenkommunikation (Art. 14 DORA) festlegen.

Unter anderem im Rahmen der IKT-Geschäftsfortführungsleitlinie und insbesondere im Kontext von IKT-bezogenen Vorfällen sind Kommunikations- und Krisenmanagementmaßnahmen einzurichten. Diese Maßnahmen zielen sowohl auf die Information von externen Interessenträgern von involvierten internen Mitarbeitern (Art. 11 Abs. 2 lit. e i. V. m. Art. 14 und 19 DORA; Art. 24 Abs. 1 lit. a Ziffer iv und lit. b Ziffer vi RTS RMF). Zur Umsetzung müssen Kommunikationsstrategien und -leitlinien entwickelt werden, die die Informationsbedürfnisse der Mitarbeiter, die an Reaktion und Wiederherstellung beteiligt sind und des weiteren zu informierenden Personals berücksichtigen (Art. 14 Abs. 2 DORA).

5. IT-Projektmanagement und Anwendungsentwicklung

In diesem Abschnitt werden die Vorgaben der Artt. 15, 16, 17 RTS RMF an das IKT-Projekt- und Änderungsmanagement den Anforderungen an das IT-Projektmanagement und -Anwendungsentwicklung der Kapitel 7 BAIT/VAIT gegenübergestellt.

Insgesamt ist festzuhalten, dass die Einzelanforderungen, mit spezifischer IT-Sicherheitsausprägung im RTS RMF deutlich mehr Details enthalten als die BAIT/VAIT im Kapitel zu IT-Projekten und Anwendungsentwicklung. Der Fokus im RTS liegt klar auf der Implementierung von geeigneten Maßnahmen zur Erfüllung der Sicherheitsziele und weniger auf der Governance von bestimmten Prozessen, wie in den BAIT/VAIT. Die im RTS RMF gelisteten Maßnahmen stellen Mindestanforderungen dar und sollten nicht als abschließend interpretiert werden. Flankierende Maßnahmen zu den Mindestanforderungen können auch hier nach dem Grundsatz der Verhältnismäßigkeit eingefordert werden.

Bei umgesetzter BAIT/VAIT ergeben sich durch die neue Regulatorik Freiheitsgrade bei der Umsetzung der Anforderungen. In DORA werden in Bezug auf das IKT-Projekt- und Änderungsmanagement weniger Details sowie Beispiele genannt. Vielmehr wird das Sicherheitsniveau über Mindestanforderungen definiert, die Umsetzung jedoch freier

gestaltet. Moderate Mehraufwände sind dennoch erforderlich, um u. a. die Quellcodes zu prüfen und die weggefallene Wesentlichkeitsgrenze umzusetzen.

5.1 Vergleichbare Anforderungen im IKT-Projektmanagement

Die grundsätzlichen Anforderungen an eine IKT-Projektmethodik (Art. 15 RTS RMF), die anhand einer entsprechenden Richtlinie umzusetzen sind, enthält, analog zur Tz. 7.3 BAIT/ Tz. 7.4 VAIT, auch der RTS RMF (Art. 15 Abs. 1 - 3 RTS RMF). Erleichterungen ergeben sich bei der Betrachtung von Korrelationen über mehrere Projekte hinweg. Hier sehen die BAIT/VAIT bisher vor, dass eine Risikobetrachtung bezüglich der Abhängigkeiten von IT-Projekten untereinander zu erfolgen hat. DORA fordert diese Betrachtung nicht mehr. Stattdessen muss eine Bewertung der Projekte unter Berücksichtigung der Auswirkungen auf kritische und wichtige Funktionen erfolgen und dem Leitungsorgan in Abhängigkeit zur Wichtigkeit und Projektgröße kommuniziert werden (Art. 15 Abs. 5 RTS RMF).

Weitere Erleichterungen ergeben sich durch den Wegfall der Anforderungen zur qualitativen und quantitativen Ressourcenausstattung sowie Einschränkungen bei der Informationssicherheitssicht, welche lediglich die Einhaltung der Schutzziele (Art. 15 Abs. 1 RTS RMF) fordert. Anforderungen bzgl. einer Projektdokumentation und Lessons-Learned sind ebenfalls nicht Bestandteil des RTS RMF.

5.2 Detailvorgaben zu IKT-System Beschaffung, Entwicklung und Instandhaltung

Der RTS RMF ist im Vergleich zu den BAIT/VAIT deutlich detaillierter und enthält konkrete Mindestbestandteile für eine Richtlinie zur Beschaffung, Entwicklung und Instandhaltung (Art. 16 Abs. 1 RTS RMF). Im Gegensatz zu den BAIT/VAIT liegt der Fokus weniger auf der Dokumentation der Anwendungsentwicklung und stattdessen mehr auf der sicheren Implementierung (Art. 16 Abs. 1 lit. a und c RTS RMF) und der Identifizierung der zur Umsetzung der Anwendung benötigten Anforderungen (Art. 16 Abs. 1 lit. b RTS RMF). Eine vollständige Dokumentation von Anforderungen im Sinne eines Fachkonzepts oder Lastenhefts wird nicht explizit gefordert.

Der RTS RMF beschreibt sehr detailliert die durchzuführenden Maßnahmen zum Testen von IT-Systemen (Art. 16 Abs. 2 RTS RMF). So sind künftig beispielsweise Sicherheitstests im Rahmen der Quellcodeüberprüfung für Systeme und Anwendungen mit Internetkonnektivität notwendig (Art. 16 Abs. 3 RTS RMF).

Die VAIT fordern an dieser Stelle hingegen lediglich die Einführung eines Regelprozesses, ohne konkrete Testverfahren oder Szenarien zu benennen.

Im Vergleich zu den BAIT/VAIT werden keine Anforderungen an Stressbelastungsszenarien oder der Dokumentation der Tests mehr gestellt. Allerdings fordert Art. 17 RTS RMF für Änderungen ein wirksames Testverfahren, inkl. einer Qualitätssicherung (Art. 17 Abs. 1 lit. c Ziffer ii RTS RMF), was wiederum für die Erstellung einer Dokumentation spricht.

Im Umgang mit Quellcode aus der Anwendungsentwicklung, enthält der RTS RMF sehr spezifische Anforderungen. So muss der Quellcode unter Einsatz von statischen und dynamischen Testverfahren vor dem produktiven Einsatz auf Anomalien überprüft werden (Art. 16 Abs. 3 RTS RMF). Dies gilt im Übrigen auch für durch Dritte erstellten Quellcode und proprietäre Software (kompilierter Quellcode) (Art. 16 Abs. 8 RTS RMF).

Die individuelle Datenverarbeitung (IDV) ist im RTS RMF nur implizit enthalten. So wird keine Unterscheidung zwischen IDV und zugekauften (Standard-)Anwendungen getroffen, sondern darauf hingewiesen, dass Entwicklungen außerhalb der IT-Funktion auf Risiken hin zu überprüfen sind (Art. 16 Abs. 9 RTS RMF). Die wesentlichen Anforderungen an IDV bleiben zwar bestehen, die Prüfung fällt ggf. aufgrund der fehlenden Sonderstellung der IDV umfangreicher aus als bisher.

5.3 Wegfall der Wesentlichkeitsgrenze im IKT-Änderungsmanagement

Für das IKT-Änderungsmanagement (Art. 17 RTS RMF) ergeben sich insbesondere bezüglich der Bewertung von Änderungen an Software, Hardware, Firmware, Systemen oder Sicherheitsparametern (Art. 17 Abs. 1 RTS RMF) Neuerungen im Vergleich zu den bestehenden Anforderungen der BAIT/VAIT. An dieser Stelle ändert sich insbesondere die Sichtweise, da im Mittelpunkt der Betrachtung nun Daten als schützenswertes Asset und die eingesetzte Technologie stehen (Art. 17 Abs. 1 RTS RMF). Die BAIT/VAIT betrachten im Gegensatz dazu die Auswirkung der Änderungen im Kontext der gesamten IT-Organisation im Rahmen einer Auswirkungsanalyse. Der RTS RMF enthält allerdings konkrete Anforderungen für den operativen Ablauf bei der Behandlung von Änderungen (Art. 17 Abs. 1 RTS RMF). Erwähnt wird hier u. a. die Funktions- und Rollentrennung (Art. 17 Abs. 1 lit. b RTS RMF) bei der Genehmigung von Änderungen. Die Implementierung eines konkreten Prozesses wird nicht beschrieben bzw. gefordert.

Kapitel 7.1 BAIT/VAIT sahen bisher vor, dass wesentliche Änderungen einem vorgeschriebenen Analyseprozess unterliegen müssen und in Abhängigkeit zur Wesentlichkeit der Änderungen weitere, betroffene Organisationseinheiten zu beteiligen sind. Der RTS RMF trifft keine Unterscheidung mehr zwischen wesentlicher und nicht wesentlicher Änderung. Daher müssen künftig alle Änderungen an IKT-Systemen auf kontrollierte Weise erfasst, getestet, bewertet, genehmigt, implementiert und überprüft werden (Art. 17 Abs. 1 lit. c RTS RMF). Die in den BAIT/VAIT vorgesehene Beteiligung weiterer Organisationseinheiten wird im RTS RMF nicht explizit gefordert.

6. IKT-Drittparteienrisikomanagement

In diesem Abschnitt werden die Anforderungen der Artt. 1, 5 und Kapitel V Abschnitt I (Artt. 28 - 30) DORA, des RTS TPPol und des RTS-E-SUB an das IKT-Drittparteienrisikomanagement denen des Kapitels 9 der BAIT („Auslagerungen und sonstiger Fremdbezug von IT-Dienstleistungen“), bzw. des Kapitels 9 der VAIT („Ausgliederungen von IT-Dienstleistungen und sonstige Dienstleistungsbeziehungen im Bereich IT-Dienstleistungen“) gegenübergestellt. Auszüge der Mindestanforderungen an das Risikomanagement (AT 9 MaRisk) bzw. Mindestanforderungen an die Geschäftsorganisation von Versicherungsunternehmen

(Kapitel 13 MaGo) werden aufgrund der engen Verflechtung mit den Anforderungen der BAIT bzw. VAIT ebenfalls betrachtet.

DORA regelt im Kapitel V die Nutzung von IKT-Dienstleistungen, die von IKT-Drittdienstleistern bereitgestellt werden. Dazu werden eine Reihe von Schlüsselprinzipien für ein solides Management des IKT-Drittparteienrisikos definiert. Diese umfassen Anforderungen an die Governance, den Lebenszyklus eines IKT-Dienstleistungsbezugs, den Umgang mit bestimmten IKT-Drittparteienrisiken und den Mindestvertragsinhalten. Eine Auflistung der Mindestvertragsinhalte findet sich als Anhang zu diesen Umsetzungshinweisen.

6.1 Abgrenzung zu Auslagerung und Ausgliederung

Das IKT-Drittparteienrisikomanagement nach DORA ergänzt die bestehenden sektoralen Regelungen zu Auslagerungen oder Ausgliederungen⁶ (im Folgenden nur „Auslagerung“). Die sektorspezifischen Auslagerungsanforderungen sind somit weiterhin zu beachten, d. h. sowohl die gesetzlichen Anforderungen als auch die Vorgaben z. B. aus MaRisk oder MaGo sind weiterhin anwendbar, sie bestehen parallel und komplementär. Dadurch ist anzunehmen, dass in vielen Fällen eine vertragliche Vereinbarung über die Nutzung von IKT-Dienstleistungen auch eine Auslagerung darstellt (und umgekehrt). Eine Harmonisierung der Anforderungen an das IKT-Drittparteienrisikomanagement unter DORA und der sektoralen Anforderungen an Auslagerungen wird aufsichtsseitig angestrebt.

Aus diesem Grund betrachtet dieses Kapitel der Umsetzungshinweise nicht allein die wesentlichen Auswirkungen aus Unterschieden zwischen DORA und BAIT/VAIT, sondern auch die einschlägigen Abschnitte der MaRisk und MaGo.

Die Definition von vertraglichen Vereinbarungen zur Nutzung von IKT-Dienstleistungen (Art. 28 Abs. 1 lit. a i. V. m. Art. 3 Nr. 21 DORA) ist deutlich weiter gefasst als die bisherigen Auslagerungsdefinitionen, insbesondere, weil sie sich für Finanzunternehmen auf alle „IKT-Dienstleistungen für die Ausübung ihrer Geschäftstätigkeit“ bezieht. Dadurch wird eine Einwertung aller Drittbezüge mit IKT-Bezug notwendig und es ergeben sich in der Umsetzung ggf. Unsicherheiten zur korrekten Klassifizierung. Zusätzlich ist in vielen Fällen mit einer Ausweitung der abzudeckenden Sachverhalte zu rechnen.

Von besonderer Bedeutung für den Umfang der zu erfüllenden Anforderungen ist, ob die bezogene IKT-Dienstleistung eine kritische oder wichtige Funktion unterstützt. In einem solchen Fall wird von einer besonderen Bedeutung der verbundenen IKT-Drittparteienrisiken ausgegangen. Die Bewertung von Funktionen als „kritisch oder wichtig“ ist methodisch und inhaltlich nicht identisch mit einer Wesentlichkeitsbestimmung bei Auslagerungen⁷. Sie erfolgt auf Basis der Auswirkungen, die ein Ausfall oder eine eingeschränkte Leistung der Funktion zur Folge hätte (Art. 3 Nr. 22 DORA). Auch hier ist die Entwicklung von geeigneten Kriterien zur Einstufung (Art. 3 Abs. 2 RTS TPPol) und die Bewertung aller Sachverhalte notwendig.

⁶ DORA Erwägungsgrund 29: „Daher müssen bestimmte Schlüsselprinzipien festgelegt werden, die Finanzunternehmen als Richtschnur für das Management des IKT-Drittparteienrisikos dienen [...]. Diese Prinzipien ergänzen die für die Auslagerung geltenden sektorspezifischen Rechtsvorschriften.“

⁷ Bzw. Bewertung der Frage, ob eine wichtige Funktion oder Versicherungstätigkeit i. S. d. VAG vorliegt.

6.2 Ausweitung der Vertragsanforderungen

Mit DORA geht eine deutliche Ausweitung der mit dem IKT-Drittdienstleister verpflichtend zu vereinbarenden Vertragsinhalte⁸ einher. Diese sind insbesondere:

- Formvorschriften, u. a. Form und Abbildung in einem Dokument (Art. 30 Abs. 1 DORA und Art. 8 Abs. 4 RTS TPPol),
- Mindestinhalte für alle vertraglichen Vereinbarungen (Art. 30 Abs. 2 DORA),
- Mindestinhalte für vertragliche Vereinbarungen zur Unterstützung kritischer oder wichtiger Funktionen (Art. 30 Abs. 3 DORA und Art. 8 ff. RTS TPPol),
- Kündigungsrechte (Art. 28 Abs. 7 DORA sowie Art. 7 RTS-E SUB),
- relevante Vertragsinhalte zu Anforderungen aus Art. 1 Abs. 1 lit. a und anderen relevanten Gesetzen (Art. 8 Abs. 1 RTS TPPol),
- Prüfungs- und ggf. Testrechte (Art. 8 Abs. 1 RTS TPPol i. V. m. Art. 1 Abs. 1 lit. a Ziffer iv DORA, Art. 8 Abs. 2, Art. 8 Abs. 3 lit. g und h sowie Art. 3 Abs. 8 lit. c und d RTS TPPol),
- Verpflichtung der Nachbildung der relevanten Vertragsinhalte bei Unterauftragsvergaben zur Unterstützung kritischer oder wichtiger Funktionen (Art. 3 Abs. 1 lit. c RTS-E SUB),
- Beschreibung und Bedingungen unter denen eine Unterauftragsvergabe zulässig ist (Art. 30 Abs. 2 lit. a DORA, Art. 4 RTS-E SUB),
- eine ausreichende Mitteilungsfrist im Fall von wesentlichen Veränderungen bei Unterauftragsvergaben für kritische oder wichtige Funktionen und Verpflichtung, in dieser Frist keine Änderungen zu vollziehen, sowie das Recht Änderungen zu verlangen (Art. 6 Abs. 1, 3 und 4 RTS-E SUB) sowie
- Maßnahmen und Messgrößen („key indicators“) zur Überwachung der Leistungsfähigkeit, Anforderungen zur Informationssicherheit und der Einhaltung von Leitlinien und Prozessen des Finanzunternehmens sowie, wenn angemessen, Vertragsstrafen (Art. 9 Abs. 1 RTS TPPol).

Durch die deutliche Ausweitung des Anwendungsbereichs und der verpflichtend zu vereinbarenden Vertragsinhalte ist in vielen Fällen eine Neu- bzw. Nachverhandlung eines großen Teils der Verträge mit IKT-Drittdienstleistern notwendig. Hinzu kommt, dass die verpflichtenden Vertragsinhalte auch vertragliche Vereinbarungen abdecken, die nicht kritische oder wichtige Funktionen unterstützen bzw. keine wesentlichen Auslagerungen⁹ betreffen.

Es sollen bei Vertragsabschluss Standardvertragsklauseln berücksichtigt werden, die von Behörden für bestimmte Dienstleistungen entwickelt wurden (Art. 30 Abs. 4 DORA). Aktuell liegen allerdings keine Standardvertragsklauseln vor, beaufsichtigte Unternehmen sollten daher nicht die Veröffentlichung von Standardvertragsklauseln zur Umsetzung der Mindestvertragsinhalte abwarten.

⁸ In die Auflistung wurden nur Anforderungen aufgenommen, die auf Level 1 oder Level 2 explizit als Mindestvertragsinhalte dargestellt sind. Weitere Vertragsinhalte, die sich aus anderen Anforderungen ergeben, oder die sinnvollerweise vereinbart werden sollten, wurden nicht aufgenommen.

⁹ bzw. Bewertung der Frage, ob eine wichtige Funktion oder Versicherungstätigkeit i. S. d. VAG vorliegt.

Es sind keine erweiterten Übergangsfristen für die Anpassung der bestehenden vertraglichen Vereinbarungen (Risikoanalysen, Vertragsinhalte) vorgesehen. Art. 3 Abs. 1 RTS TPPol weist darauf hin, dass es einen dokumentierten Implementierungszeitplan geben soll und die Umsetzung rechtzeitig erfolgen soll. Die Anpassung der vertraglichen Vereinbarungen soll sobald wie möglich vorgenommen werden.

6.3 Neuregelung von Unterauftragsvergaben

Unterauftragsvergaben für kritische oder wichtige Funktionen werden in dem RTS-E SUB umfassend geregelt, der Anfang Dezember im Entwurf veröffentlicht wurde¹⁰. In dem RTS kommt es zu einer deutlichen Ausweitung der Regulierungsbreite und -tiefe:

- Das Finanzunternehmen muss beurteilen, ob der IKT-Drittdienstleister in der Lage ist, einen Unterauftragnehmer geeignet auszuwählen und angemessen zu überwachen (Art. 3 Abs. 1 RTS-E SUB).
- Vertragsinhalte bezogen auf Unterauftragnehmer (Art. 4 RTS-E SUB).
- Dokumentation und Überwachung von Ketten der Unterauftragsvergabe (Art. 5 RTS-E SUB).
- Vorgehen bei wesentlichen Änderungen (Art. 6 RTS-E SUB) und ggf. damit verbundene Kündigungsrechte (Art. 7 RTS-E SUB).

6.4 Umfangreiche Anforderungen an Risikoanalysen und Due-Diligence

Der Umfang der Anforderungen an Risikoanalysen und Due-Diligence, insbesondere bei vertraglichen Vereinbarungen, die kritische oder wichtige Funktionen betreffen, sind gestiegen. Dies betrifft vor allem den Inhalt und die Tiefe der Analyse. Die Inhalte für IKT-Dienstleistungen, die keine kritischen oder wichtigen Funktionen unterstützen, werden nur recht allgemein ausgeführt:

- Beurteilung der Einhaltung aufsichtsrechtlicher Bedingungen (Art. 28 Abs. 4 DORA),
- Ermittlung und Bewertung aller relevanten Risiken, einschließlich des IKT-Konzentrationsrisikos (Art. 28 Abs. 4 DORA),
- Eignung des IKT-Drittdienstleisters im Rahmen einer Due-Diligence (Art. 28 Abs. 4 DORA),
- Ermittlung und Bewertung von Interessenkonflikten¹¹ (Art. 28 Abs. 4 DORA) sowie die
- Einhaltung angemessener Standards der Informationssicherheit (Art. 28 Abs. 5 DORA).

Bei IKT-Dienstleistungen, die kritische oder wichtige Funktionen unterstützen, kommen weitere zu analysierende Sachverhalte hinzu, die im Umfang die bisherigen Anforderungen z. T. deutlich übersteigen:

¹⁰ Da sich der RTS zur Unterauftragsvergabe in der Gruppe der RTS/ITS mit 18 Monaten Bearbeitungszeit befindet, ist noch mit Änderungen nach Ablauf der Konsultationsfrist am 04.03.2024 zu rechnen.

¹¹ Für IKT-Dienstleistungen, die kritische oder wichtige Funktionen unterstützen, auch Art. 7 RTS TPPol.

- Konkrete Benennung eines Mindestkatalogs an Risiken, die im Rahmen der Ex-ante Risikoanalyse zu berücksichtigen sind, dazu gehören Operationelle Risiken, Rechtsrisiken, IKT-Risiken, Reputationsrisiken, Geheimhaltungs- und Datenschutzrisiken, Risiken in Bezug auf die Verfügbarkeit von Daten, Risiken im Zusammenhang des mit dem Ort der Datenverarbeitung und -speicherung, Standort des IKT-Drittdienstleisters, Konzentrationsrisiko (Art. 5 Abs. 2 RTS TPPol).
- Konkrete Benennung eines Mindestkatalogs an Faktoren, die der IKT-Drittdienstleister erfüllen soll, darunter Reputation, Fähigkeiten, IKT-Risikomanagement, Unterauftragsvergabe, Standort, Prüffähigkeit, ESG-Anforderungen (Art. 6 Abs. 1 RTS TPPol).
- Abwägung Vorteile und Risiken im Zusammenhang mit Unterauftragsvergaben (Art. 29 Abs. 2 DORA, Art. 1 RTS-E SUB) und Bewertung langer und komplexer Ketten der Unterauftragsvergabe (Art. 29 Abs. 2 DORA).
- Berücksichtigung von Rechtsrisiken, d.h. der Bestimmungen des Insolvenzrechts (Art. 29 Abs. 2 DORA) und bei Drittländern die Einhaltung und Durchsetzbarkeit von Rechtsvorschriften und die Einhaltung von Datenschutzvorschriften (Art. 29 Abs. 2 DORA).
- Bewertung, ob der IKT-Drittdienstleister über ausreichende Ressourcen verfügt, um gesetzliche und regulatorische Anforderungen einzuhalten (Art. 3 Abs. 4 RTS TPPol)
- Angemessene Berücksichtigung von „aktuellsten und höchsten Qualitätsstandards für die Informationssicherheit“ (Art. 28 Abs. 5 DORA).

Ebenfalls sind bei kritischen oder wichtigen Funktionen im Rahmen der Due-Diligence, insoweit angemessen, bereits vor Vertragsabschluss auch Prüf- oder Assessmentergebnisse des IKT-Drittdienstleisters heranzuziehen (Art. 6 Abs. 3 lit. a und b RTS TPPol). Eine Bereitstellung solcher Prüf- oder Assessmentberichte dürfte einen Teil der Drittdienstleister vor Herausforderungen stellen.

6.5 Geänderte Anforderungen an den Ausstieg

Die Anforderungen an Ausstiegsstrategien/-pläne für IKT-Dienstleistungen zur Unterstützung kritischer oder wichtiger Funktionen steigen deutlich, insbesondere sind die Erwartungen an die Ziele der Ausstiegsstrategien deutlich ausgeweitet (Art. 28 Abs. 8 DORA). So sollen Finanzunternehmen ohne Unterbrechung ihrer Geschäftstätigkeit und ohne Beeinträchtigung ihrer für Kunden erbrachten Dienstleistungen oder der Einhaltung regulatorischer Anforderungen aus vertraglichen Vereinbarungen ausscheiden können. Die Ausstiegspläne sollen auf plausiblen Szenarien und angemessenen Annahmen beruhen (Art. 10 RTS TPPol). Zudem sind die Ausstiegspläne ausreichend zu testen und sollen regelmäßig überprüft werden.

Die bisherige Öffnungsklausel für gruppen- oder verbundinterne Auslagerungen bei Kreditinstituten (Verzicht auf Ausstiegsprozesse gemäß AT 9 Tz. 15 d MaRisk) entfällt, wenn diese gleichzeitig IKT-Dienstleistungen sind. Eine Berücksichtigung der Proportionalität ist aber weiterhin in Bezug auf ein reduziertes Risiko (insoweit zutreffend) möglich (Art. 1 lit. e RTS

TPPol¹²). Dies betrifft auch IKT-Drittdienstleister, die selbst unter Aufsicht stehen oder überwacht werden (Art. 1 lit. g RTS TPPol).

Unter DORA kommt es zu einer umfangreichen und sehr konkreten Berücksichtigung von Konzentrationsrisiken mit dem Ziel, diese zu ermitteln und angemessen zu überwachen. Dazu wird bei vertraglichen Vereinbarungen, die kritische oder wichtige Funktionen betreffen, ermittelt und bewertet, ob der IKT-Drittdienstleister nicht ohne Weiteres ersetzbar wäre oder ob es einen mehrfachen Bezug von IKT-Dienstleistungen von einem IKT-Drittdienstleister gibt. Wenn Konzentrationsrisiken vorliegen, müssen Finanzunternehmen den Nutzen und die Kosten alternativer Lösungen abwägen (Art. 29 Abs. 1 DORA). Dieses Konzentrationsrisiko fließt sowohl in die Ex-ante Risikoanalyse nach Art. 5 RTS TPPol als auch in die Analysen für Unterauftragsvergaben nach Art. 3 Abs. 1 lit. h RTS-E SUB ein.

6.6 Veränderungen an der Governance des IKT-Drittparteienrisikos

Veränderungen ergeben sich auch im Bereich der Governance, insbesondere kommt es zu einer verstärkten Einbindung des Leitungsorgans, z. B. durch die Überprüfung der IKT-Drittparteienrisiken (Art. 28 Abs. 2 DORA) oder der Genehmigung der Leitlinie für die Nutzung von IKT-Dienstleistungen, die kritische oder wichtige Funktionen unterstützen (Art. 5 Abs. 2 lit. h DORA und Art. 3 Abs. 1 RTS TPPol), sowie Meldekanäle zur Nutzung von IKT-Dienstleistungen (Art. 5 Abs. 2 lit. i DORA). Eine Funktion zur Überwachung der mit IKT-Drittdienstleistern über die Nutzung von IKT-Dienstleistungen geschlossenen Vereinbarungen ist einzurichten (Art. 5 Abs. 3 DORA, s. auch Abschnitt 1.2), die mit dem (zentralen) Auslagerungsbeauftragten vergleichbar ist.

6.7 Hinweis zu Meldepflichten und Informationsregister

Meldepflichten, insbesondere bezogen auf das Informationsregister, den jährlichen Bericht an die zuständigen Behörden und die Meldung von beabsichtigten vertraglichen Vereinbarungen (Art. 28 Abs. 3 DORA) sind jedoch nicht Gegenstand dieser Umsetzungshinweise.

7. Operative Informationssicherheit

In diesem Abschnitt werden die Anforderungen an Daten- und Systemsicherheitsmaßnahmen der Artt. 9, 10 DORA und Artt. 6, 7, 10, 11, 12, 13, 14, 22 und 23 RTS RMF denen der operativen Informationssicherheit der Kapitel 5 BAIT/VAIT gegenübergestellt.

Für den Bereich der operativen Informationssicherheit in DORA ist insgesamt festzustellen, dass der Detaillierungsgrad der Anforderungen deutlich höher ausfällt als bisher in Kapitel 5 BAIT/VAIT beschrieben. Der Grad der Detaillierung entspricht eher den

¹² Siehe Erwägungsgrund 5 RTS TPPol in Bezug auf Verbundinstitute: „When applying the policy, ICT intra-group service providers, including those fully or collectively owned by financial entities within the same institutional protection scheme, should be considered as ICT third-party services providers.“

Erläuterungen der BAIT/VAIT als Mindestanforderungen für angemessene Informationssicherheitsmaßnahmen und Prozesse.

In Art. 11 RTS RMF werden Daten- und Systemsicherheitsmaßnahmen gefordert, die sicherstellen, dass:

- Härtingsmaßnahmen ergriffen und diese regelmäßig kontrolliert werden,
- der Einsatz von Software und mobilen Datenträgern nur nach Erteilung einer Erlaubnis erfolgt (White-List-Approach),
- Regelungen für mobiles Arbeiten in Bezug auf erlaubte Geräte und Software bestehen,
- Verfahren zum sicheren Löschen von Informationen und Vernichten von Datenträgern vorhanden sind und
- Maßnahmen zum Schutz vor dem absichtlichen bzw. versehentlichen Verlust von Daten implementiert sind.

Zudem gelten verschärfte Anforderungen an IKT-Systeme, die von IKT-Drittdienstleister betrieben werden. Dazu zählt,

- dass Herstellerempfehlungen auf vom Institut betriebenen IKT-Systemen umgesetzt werden,
- Informationssicherheitsrollen und -verantwortlichkeiten klar zwischen Finanzunternehmen und IKT-Drittdienstleister geregelt sind,
- ausreichend Fähigkeiten zur Verwaltung und zur Sicherheit der eingesetzten IKT-Lösung im Finanzunternehmen verbleiben und
- technische und organisatorische Maßnahmen implementiert wurden, um die Risiken durch die Nutzung des IKT-Drittdienstleisters auf die eigene Infrastruktur zu verringern.

7.1 Gestärkte Netzwerksicherheit

Im Art. 13 RTS RMF finden sich hinsichtlich der Netzwerksicherheit Anforderungen, die bereits aus den Kapiteln 4.3 u. 5.2 BAIT/VAIT bekannt sind. Hierzu kommen detaillierte Anforderungen zu bspw. die Segmentierung und Segregation des Netzwerks, Netzwerkzugangskontrolle und Fremdgeräteerkennung, Härtung aller Netzwerkkomponenten sowie Reviews der Netzwerkarchitektur. Ein größerer Implementierungsaufwand wird in der Umsetzung der Anforderung in Art. 9 Abs. 4 lit. b DORA zur automatisierten Isolierungen von Informationsassets im Falle von Cyberangriffen vermutet. Diese werden in Art. 13 Abs. 1 lit. j RTS RMF weiter konkretisiert.

Mit steigenden Anforderungen an die Netzwerksicherheit wird auch die Rolle von Firewalls stärker hervorgehoben. Für Firewall-Regeln ist demnach ein Lebenszyklus mit definierten Rollen und Verantwortlichkeiten sowie einer Firewall-Rezertifizierung festzulegen (Art. 13 Abs. 1 lit. h RTS RMF). Dabei sind Firewall-Regeln, die in IKT-Systemen kritische oder wichtige Funktionen unterstützten, analog zu den Regelungen im Access Management mindestens halbjährlich zu rezertifizieren.

Der Schutz von Informationen während der Übertragung (in transit) wird in Art. 14 RTS RMF besonders betont. Hierbei werden allerdings keine konkreten Vorgaben gemacht, sondern Richtlinien und Verfahren gefordert, die dies unter Berücksichtigung des Risikoprofils sicherstellen (Art. 14 Abs. 2 RTS RMF). Neu ist gemäß Art. 14 Abs. 1 lit. c RTS RMF auch, dass für Risiken die nicht technisch mitigiert werden können, Vertraulichkeitserklärungen bzw. Geheimhaltungsvereinbarungen (Non-Disclosure-Agreements, NDA) mit Mitarbeitern des Finanzunternehmens als auch mit den betroffenen Mitarbeitern der IKT-Drittdienstleister zu schließen sind.

7.2 Verschlüsselung von Daten auch während der Verarbeitung

Art. 9 DORA sowie Artt. 6 und 7 RTS RMF, stellen im Vergleich zur Tz. 5.2 BAIT/VAIT deutlich höhere Anforderungen an die Verschlüsselung von Informationen. Es wird gefordert, dass Daten entsprechend ihrer Kritikalität in allen Zuständen zu verschlüsseln (at rest, in transit & in use) sind. Während die Anforderungen an eine Verschlüsselung von gespeicherten Daten und während der Übertragung gemäß Schutzbedarf in der Tz. 5.2 BAIT/VAIT gefordert werden, stellt die Anforderung gemäß Art. 9 Abs. 2 DORA an eine Verschlüsselung von Daten während der Verarbeitung „in use“ ein Novum dar, welches mit einem erheblichen Implementierungsaufwand verbunden sein dürfte. Für diese Anforderungen gilt, dass in den Fällen, in denen eine Verschlüsselung während der Verarbeitung nicht möglich ist, Daten in separierten und besonders geschützten Umgebungen verarbeitet werden müssen oder anderer geeigneter Maßnahmen zu treffen sind.

Neu ist zudem, dass kryptographische Schlüssel, die in BAIT/VAIT bisher nicht direkt adressiert waren, in Art. 7 RTS RMF nun dediziert behandelt werden. So sind eine Richtlinie und Verfahren für den Umgang mit kryptografischen Schlüsseln sowie Maßnahmen zu deren Schutz zu etablieren. Dabei ist der komplette Lebenszyklus von Generierung bis zur Vernichtung zu berücksichtigen. Sollten Schlüssel verloren gehen, beschädigt oder kompromittiert werden, ist sicherzustellen, dass diese ersetzt werden können. Gemäß Art. 7 Abs. 4 RTS RMF ist mindestens für diejenigen IKT-Assets, die kritische oder wichtige Funktionen unterstützen, ein stets auf dem neusten Stand zu haltendes Register aller Zertifikate und Zertifikatspeicher zu führen.

7.3 Zeitnahe Erkennung und Behandlung von Schwachstellen

Die zeitnahe Erkennung, Umgang und Behandlung von Schwachstellen wird in Art. 10 RMF RTS geregelt. Demnach müssen Finanzunternehmen sicherstellen, dass

- IKT-Drittdienstleister Schwachstellen angehen, die die von Finanzunternehmen betroffenen IKT-Systeme betreffen und diese dem Finanzunternehmen im Falle von kritischen Schwachstellen und Statistiken und Trends zeitnah melden,
- Schwachstellen auch verantwortungsvoll und angemessen an Externe und ggf. die Öffentlichkeit kommuniziert werden,
- automatisierte Schwachstellenscans zur zeitnahen Identifizierung durchgeführt werden, wobei ein mindestens wöchentlicher Schwachstellenscan für IKT-Systemen, welche kritische und wichtige Funktionen unterstützten, erforderlich ist,

- auch fremdbezogene und quelloffene Softwarebibliotheken, in den Schwachstellenprozess einbezogen werden.

Schwachstellen sind gemäß einer vom Finanzunternehmen erarbeiteten Priorisierung abzustellen (Art. 10 Abs. 2 lit. f RTS RMF), wobei die Kritikalität der Schwachstelle, Klassifizierung des Assets und das Risikoprofil zu berücksichtigen sind. Das Patchen von Schwachstellen ist anderen Maßnahmen gegenüber zu priorisieren. Soweit möglich sind verfügbare Software- und Hardware-Patches und -Aktualisierungen mithilfe automatisierter Tools zu ermitteln und zu bewerten (Art. 10 Abs. 4 lit. a RTS RMF). Für das Einspielen von Patches in „Notfällen“ ist ein gesondertes Verfahren zu erstellen (Art. 10 Abs. 4 lit. b RTS RMF). Wenn Patches nicht innerhalb der vorgegebenen Fristen installiert werden, ist ein definiertes Eskalationsverfahren einzuleiten (Art. 10 Abs. 4 lit. d RTS RMF).

Die aus Art. 5.3 BAIT/VAIT bekannten Gefährdungen des Informationsverbunds werden in DORA nicht über „potentiell sicherheitsrelevante Informationen“ identifiziert, sondern über „anomale Aktivitäten“ (Art. 10 DORA).

Unterstützt durch geeignete Verfahren müssen hierzu anomale Aktivitäten und Verhaltensweisen erkannt (Art. 10 Abs. 1 DORA), Frühwarnindikatoren (Art. 17 Abs. 3 lit. a DORA) identifiziert und alle Erkennungsmechanismen regelmäßig getestet (Art. 25 DORA) werden, welche in einem vordefinierten Zeitraum innerhalb und außerhalb der regulären Arbeitszeit abzuarbeiten sind (Art. 23 Abs. 2 lit. c RTS RMF). Dafür sollten ausreichende technische und organisatorische Ressourcen eingeplant werden.

Der Vollständigkeit halber sei erwähnt, dass DORA innerhalb des IKT-Risikomanagements auf umfangreiche Zusatzanforderungen zur Behandlung, Klassifizierung und Berichterstattung von IKT-bezogenen Vorfällen (vgl. Kapitel III, Artt. 17 - 23 DORA) und das Testen (vgl. Kapitel IV, Artt. 24 - 27 DORA) verweist. Die Kapitel III und IV DORA sind jedoch nicht Gegenstand dieser Umsetzungshinweise. Allerdings wurde erkannt, dass insbesondere die Erkennung von anomalen Verhalten über den bisherigen stark Use-Case getriebenen Ansatz der Kapitel 5.4 BAIT/VAIT hinausgeht.

Als Grundlage für die Erkennung von anomalen Aktivitäten werden umfangreiche Anforderungen an das Logging in Art. 12 RTS RMF gestellt.

- Die Aufbewahrungsdauer für Logs richtet sich dabei nach den Geschäfts- und Sicherheitsanforderungen, dem Aufbewahrungszweck und dem Risikoprofil der betroffenen IKT-Assets. Wichtig ist, dass die Entscheidung darüber ausreichend begründet und dokumentiert wird.
- Logs sind gegen Manipulation und Löschen zu schützen. Der Ausfall der Logfunktion ist zu überwachen und Ausfälle müssen erkannt werden.
- Alle IKT-Systeme des Finanzunternehmens müssen mit einer verlässlichen Referenzzeit synchronisiert werden.

8. Identitäts- und Rechtemanagement

In diesem Abschnitt werden die Vorgaben hinsichtlich des Berechtigungsmanagements der Artt. 18, 20 und 21 RTS RMF denen des Berechtigungsmanagements in Kapitel 6 BAIT/VAIT gegenübergestellt.

Hinsichtlich der Identitäts- und Rechtemanagement-Prozesse ist grundsätzlich festzuhalten, dass sich durch DORA inhaltlich nicht allzu viele Änderungen im Vergleich zur BAIT/VAIT ergeben. Bekannte Prozesse wie bspw. Antrag, Vergabe und Rezertifizierung bleiben wie in Kapitel 6 BAIT/VAIT beschrieben weiterhin bestehen. Bezogen auf Identitäts- und Rechtemanagement sind die bestehenden Anforderungen sogar detaillierter, als im RTS RMF Kapitel II vorgegeben.

8.1 Explizite Anforderungen an das Identitätsmanagement

Konkrete Anforderungen an das Identitätsmanagement werden in Art. 20 RTS RMF gestellt. Dies war in den BAIT/VAIT bisher nicht explizit gefordert, die inhaltlichen Anforderungen an ein Identitätsmanagement, als Basis für ein Zugriffs- und Zutrittsmanagement, waren aber bereits gegeben. Die Anpassungsaufwände bei bestehenden Prozessen dürften eher gering ausfallen. Gemäß Art. 20 RTS RMF sind Richtlinien und Verfahren für das Identitätsmanagement zu entwickeln, zu dokumentieren und zu implementieren. Die Richtlinien müssen vorsehen, dass

- jedem Mitarbeiter (auch von IKT-Drittdienstleistern), der auf die Informationsassets und IKT-Assets des Finanzunternehmens zugreift eine eindeutige Identität zugeordnet wird,
- diese Zuordnungen auch bei Umorganisation und nach Ablauf der Vertragsbeziehung aufbewahrt und
- ein Lebenszyklusmanagementprozess für Identitäten und Accounts eingeführt wird, wobei idealerweise automatisierte Lösungen eingesetzt werden sollen.

8.2 Einführung des „need-to-use“ Prinzips

Im Zugriffsmanagement (Art. 21 RTS RMF) wird das „need-to-know“ und „least privilege“ Prinzip aus Kapitel 6.2 BAIT/VAIT um das „need-to-use“ Prinzip ergänzt. Das neu eingeführte Prinzip spiegelt sich allerdings im Sparsamkeitsgrundsatz in Kapitel 6.2 BAIT/VAIT wider, sodass hier nicht mit erhöhten Aufwänden zu rechnen ist. Weiterhin wird u. a. gefordert, dass

- die Funktionstrennung gewährleistet wird,
- generische Accounts weitestgehend limitiert werden, sodass Aktivitäten stets eindeutig einer handelnden Person zugeordnet werden können und
- Kontrollen zur Vermeidung von unautorisiertem Zugriff eingeführt werden.

Eine Neuerung ergibt sich im Bereich der Rezertifizierung von Rechten. Diese soll für alle Berechtigungen, die kritische oder wichtige Funktionen betreffen, in einem halbjährlichen Zyklus erfolgen (Art. 21 Abs. 1 lit. e Ziffer iv RTS RMF). Für alle anderen gilt ein jährlicher

Rhythmus. Hierbei muss nicht zwischen fachlichen und technischen Zugriffen unterschieden werden.

Privilegierter Notfall oder administrativer Zugriff darf nur auf „need-to-use“ und ad-hoc Basis gewährt werden. Sofern möglich, sind hierbei automatisierte Lösungen für das privilegierte Zugriffs-Management (Privileged Access Management – PAM) zu verwenden. Privilegierte und Fernzugriffe haben mit starker Authentifizierung (entlang leading practices) zu erfolgen (Art. 21 Abs. 1 lit. f Ziffer ii RTS RMF).

III. Anhang

Hinweis

Die tabellarische Übersicht der Mindestvertragsinhalte wurde aktualisiert.

Mindestvertragsinhalte

Die vorliegende Tabelle enthält eine Übersicht der Vertragsinhalte, die gemäß DORA bzw. dem RTS TPPol und RTS-E SUB zwischen dem Finanzunternehmen und dem IKT-Drittdienstleister verpflichtend zu vereinbaren sind. Vertragsbestandteile, die idealerweise vereinbart werden sollten aber nicht explizit in den Rechtstexten aufgeführt werden, sind nicht Bestandteil dieser Auflistung. (Stand: 10. Juni 2024)

Thema	Vertragsinhalt	Fundstelle	Auszug aus dem Rechtstext	kwF ¹³
Formvorschriften	Schriftliches, dauerhaft zugängliches Dokument	Art. 30 Abs. 1 DORA	Die Rechte und Pflichten des Finanzunternehmens und des IKT-Drittdienstleisters werden eindeutig zugewiesen und schriftlich dargelegt. Der vollständige Vertrag umfasst die Vereinbarung über die Dienstleistungsgüte und wird in einem schriftlichen Dokument, das den Parteien in Papierform zur Verfügung steht, oder in einem Dokument in einem anderen herunterladbaren, dauerhaften und zugänglichen Format dokumentiert.	
Formvorschriften	Schriftliches Dokument mit Datum und Unterschrift bei wesentlichen Änderungen	Art. 8 Abs. 4 RTS TPPol	The policy shall ensure that material changes to the contractual agreement are to be formalised in a written document which is dated and signed by all parties and shall specify the renewal process for the contractual arrangements. ¹⁴	X
Beschreibung der IKT-Dienstleistung	klare und vollständige Beschreibung aller Funktionen und IKT-Dienstleistungen	Art. 30 Abs. 2 lit. a DORA	eine klare und vollständige Beschreibung aller Funktionen und IKT-Dienstleistungen, die der IKT-Drittdienstleister bereitzustellen hat, [...]	

¹³ Kennzeichnung der vertraglichen Anforderungen, die nur bei IKT-Dienstleistungen, die kritische oder wichtige Funktionen (kwF) unterstützen, erforderlich sind.

¹⁴ Darstellung der englischen Originaltexte, da zum Zeitpunkt der Tabellenerstellung (Stand: 10. Juni 2024) noch keine deutsche Übersetzung der technischen Regulierungsstandards vorlag.

Thema	Vertragsinhalt	Fundstelle	Auszug aus dem Rechtstext	kwF ¹³
Unterauftragsvergabe	Zulässigkeit Unterauftragsvergabe („die kritische oder wichtige Funktionen oder wesentliche Teile davon unterstützen“) und Bedingungen für die Unterauftragsvergabe	Art. 30 Abs. 2 lit. a DORA	[...] wobei anzugeben ist, ob die Vergabe von Unteraufträgen für IKT-Dienstleistungen, die kritische oder wichtige Funktionen oder wesentliche Teile davon unterstützen, zulässig ist, und — wenn dies der Fall ist — welche Bedingungen für diese Unterauftragsvergabe gelten	X
Standort	Standorte (Regionen oder Länder) der Verarbeitung, Speicherung und Bereitstellung	Art. 30 Abs. 2 lit. b DORA	die Standorte — das heißt die Regionen oder Länder —, an denen die vertraglich vereinbarten oder an Unterauftragnehmer vergebenen Funktionen und IKT-Dienstleistungen bereitzustellen sind und an denen Daten verarbeitet werden sollen, einschließlich des Speicherorts, [...]	
Standort	Benachrichtigung bei beabsichtigter Änderung des Standorts	Art. 30 Abs. 2 lit. b DORA	[...] sowie die Auflage für den IKT-Drittdienstleister, das Finanzunternehmen vorab zu benachrichtigen, wenn er eine Änderung dieser Standorte beabsichtigt	
Sicherheit	Schutzziele, Bestimmungen zum Datenschutz	Art. 30 Abs. 2 lit. c DORA	Bestimmungen über Verfügbarkeit, Authentizität, Integrität und Vertraulichkeit in Bezug auf den Datenschutz, einschließlich des Schutzes personenbezogener Daten	
Datenzugriff	Sicherstellung des Zugangs zu Daten (z.B. bei Insolvenz), Wiederherstellung und Rückgabe	Art. 30 Abs. 2 lit. d DORA	Bestimmungen über die Sicherstellung des Zugangs zu personenbezogenen und nicht personenbezogenen Daten, die von dem Finanzunternehmen im Fall einer Insolvenz, Abwicklung, Einstellung der Geschäftstätigkeit des IKT-Drittdienstleisters oder einer Beendigung der vertraglichen Vereinbarungen verarbeitet werden, sowie über die Wiederherstellung und Rückgabe dieser Daten in einem leicht zugänglichen Format	
Beschreibung der IKT-Dienstleistung	Beschreibungen der Dienstleistungsgüte, einschließlich Aktualisierungen und Überarbeitungen	Art. 30 Abs. 2 lit. e DORA	Beschreibungen der Dienstleistungsgüte, einschließlich Aktualisierungen und Überarbeitungen	
IKT-Vorfall	Unterstützung bei einem IKT-Vorfall, Festsetzung der Kosten	Art. 30 Abs. 2 lit. f DORA	die Verpflichtung des IKT-Drittdienstleisters, dem Finanzunternehmen bei einem IKT-Vorfall, der mit dem für das Finanzunternehmen bereitgestellten IKT-Dienst in Verbindung steht, ohne zusätzliche Kosten oder zu vorab festzusetzenden Kosten Unterstützung zu leisten	
Aufsicht	Zusammenarbeit mit zuständigen Behörden	Art. 30 Abs. 2 lit. g DORA	die Verpflichtung des IKT-Drittdienstleisters, vollumfänglich mit den für das Finanzunternehmen zuständigen Behörden und Abwicklungsbehörden zusammenzuarbeiten, einschließlich der von diesen benannten Personen	

Thema	Vertragsinhalt	Fundstelle	Auszug aus dem Rechtstext	kwF ¹³
Kündigung	Kündigungsrechte und Mindestkündigungsfristen entsprechend den Erwartungen der zuständigen Behörden	Art. 30 Abs. 2 lit. h DORA	Kündigungsrechte und damit zusammenhängende Mindestkündigungsfristen für die Beendigung der vertraglichen Vereinbarungen entsprechend den Erwartungen der zuständigen Behörden und der Abwicklungsbehörden	
Schulungen	Teilnahme an Sensibilisierungen und Schulungen des Finanzunternehmens zu IKT-Sicherheit und digitaler operationalen Resilienz	Art. 30 Abs. 2 lit. i DORA	Bedingungen für die Teilnahme von IKT-Drittdienstleistern an den von den Finanzunternehmen angebotenen Programmen zur Sensibilisierung für IKT-Sicherheit und Schulungen zur digitalen operationalen Resilienz gemäß Art. 13 Absatz 6	
Beschreibung der IKT-Dienstleistung	Vollständige Beschreibung der Dienstleistungsgüte mit präzisen quantitativen und qualitativen Leistungszielen (einschließlich Aktualisierungen und Überarbeitungen)	Art. 30 Abs. 3 lit. a DORA	vollständige Beschreibungen der Dienstleistungsgüte, einschließlich Aktualisierungen und Überarbeitungen, mit präzisen quantitativen und qualitativen Leistungszielen innerhalb der vereinbarten Dienstleistungsgüte, um dem Finanzunternehmen eine wirksame Überwachung von IKT-Dienstleistungen und das unverzügliche Ergreifen angemessener Korrekturmaßnahmen zu ermöglichen, wenn eine vereinbarte Dienstleistungsgüte nicht erreicht wird	X
Kündigung	Kündigungsfristen des IKT-Drittdienstleisters	Art. 30 Abs. 3 lit. b DORA	Kündigungsfristen und Berichtspflichten des IKT-Drittdienstleisters gegenüber dem Finanzunternehmen, einschließlich der Meldung aller Entwicklungen, die sich wesentlich auf die Fähigkeit des IKT-Drittdienstleisters, IKT-Dienstleistungen zur Unterstützung kritischer oder wichtiger Funktionen gemäß den vereinbarten Leistungsniveaus wirksam bereitzustellen, auswirken könnten	X
Berichterstattung	Berichtspflichten des IKT-Drittdienstleisters	Art. 30 Abs. 3 lit. b DORA	Kündigungsfristen und Berichtspflichten des IKT-Drittdienstleisters gegenüber dem Finanzunternehmen, einschließlich der Meldung aller Entwicklungen, die sich wesentlich auf die Fähigkeit des IKT-Drittdienstleisters, IKT-Dienstleistungen zur Unterstützung kritischer oder wichtiger Funktionen gemäß den vereinbarten Leistungsniveaus wirksam bereitzustellen, auswirken könnten	X
Geschäftsfortführungsmanagement	Implementierung und Test von Notfallplänen	Art. 30 Abs. 3 lit. c DORA	Anforderungen an den IKT-Drittdienstleister, Notfallpläne zu implementieren und zu testen [...]	X
Sicherheit	Maßnahmen zur IKT-Sicherheit (angemessenes Maß an Sicherheit, im Einklang mit dem Rechtsrahmen des Finanzunternehmens)	Art. 30 Abs. 3 lit. c DORA	Anforderungen an den IKT-Drittdienstleister [...] über Maßnahmen, Tools und Leit- und Richtlinien für IKT-Sicherheit zu verfügen, die ein angemessenes Maß an Sicherheit für die Erbringung von Dienstleistungen durch das Finanzunternehmen im Einklang mit seinem Rechtsrahmen bieten;	X

Thema	Vertragsinhalt	Fundstelle	Auszug aus dem Rechtstext	kwF ¹³
TLPT	Beteiligung und Mitwirkung an TLPT ¹⁵	Art. 30 Abs. 3 lit. d DORA	die Verpflichtung des IKT-Drittdienstleisters, sich an den in den Artikeln 26 und 27 genannten TLPT des Finanzunternehmens zu beteiligen und uneingeschränkt daran mitzuwirken	X
Überwachung	Recht zur fortlaufenden Überwachung der Leistung des IKT-Drittdienstleisters	Art. 30 Abs. 3 lit. e DORA	das Recht, die Leistung des IKT-Drittdienstleisters fortlaufend zu überwachen	X
Prüfrechte	Prüfrechte für FU und Aufsicht, inkl. Recht Kopien anzufertigen	Art. 30 Abs. 3 lit. e Ziffer i DORA	uneingeschränkte Zugangs-, Inspektions- und Auditrechte des Finanzunternehmens oder eines beauftragten Dritten und der zuständigen Behörde sowie das Recht auf Anfertigung von Kopien einschlägiger Unterlagen vor Ort, wenn ihnen für die Geschäftstätigkeit des IKT-Drittdienstleisters entscheidende Bedeutung zukommt, wobei die tatsächliche Ausübung dieser Rechte nicht durch andere vertragliche Vereinbarungen oder Umsetzungsrichtlinien behindert oder eingeschränkt wird	X
Prüfrechte	Einschränkung der Prüfrechte bei Betroffenheit Rechte anderer Kunden	Art. 30 Abs. 3 lit. e Ziffer ii DORA	das Recht, alternative Bestätigungsniveaus zu vereinbaren, wenn die Rechte anderer Kunden betroffen sind	X
Prüfrechte	Uneingeschränkte Zusammenarbeit bei Vor-Ort-Inspektion und Audit	Art. 30 Abs. 3 lit. e Ziffer iii DORA	die Verpflichtung des IKT-Drittdienstleisters zur uneingeschränkten Zusammenarbeit bei Vor-Ort-Inspektionen und Audits, die von den zuständigen Behörden, der federführenden Überwachungsbehörde, dem Finanzunternehmen oder einem beauftragten Dritten durchgeführt werden	X
Prüfrechte	Mitteilungspflicht zur Prüfungsplanung	Art. 30 Abs. 3 lit. e Ziffer iv DORA	die Verpflichtung, Einzelheiten zu Umfang und Häufigkeit dieser Inspektionen sowie dem dabei zu befolgenden Verfahren mitzuteilen	X
Prüfrechte	Wahrnehmung der Prüfungsrechte durch unabhängigen Dritten bei Finanzunternehmen, die Kleinstunternehmen sind	Art. 30 Abs. 3 DORA	Abweichend von Buchstabe e können der IKT-Drittdienstleister und das Finanzunternehmen, das ein Kleinstunternehmen ist, vereinbaren, dass die Zugangs-, Inspektions- und Auditrechte des Finanzunternehmens auf einen unabhängigen Dritten übertragen werden können, der vom IKT-Drittdienstleister benannt wird, sowie dass das Finanzunternehmen von diesem Dritten jederzeit Informationen und Gewähr in Bezug auf die Leistung des IKT-Drittdienstleisters verlangen kann.	X

¹⁵ Für einen weiteren optionalen Vertragsinhalt siehe auch Art. 26 Abs. 4 DORA.

Thema	Vertragsinhalt	Fundstelle	Auszug aus dem Rechtstext	kwF ¹³
Prüfrechte	Informationszugangs-, Inspektions-, Audit- und IKT-Prüfrechte	Art. 8 Abs. 2 RTS TPPol	The policy shall specify that the relevant contractual arrangements are to include the right for the financial entity to access information, to carry out inspections and audits, and to perform tests on ICT. For that purpose, the policy shall require that the financial entity uses the following methods, without prejudice to the ultimate responsibility of the financial entity:	X
Prüfrechte	Prüfung durch Interne Revision oder beauftragten Dritten	Art. 8 Abs. 2 lit. a RTS TPPol	its own internal audit or an audit by an appointed third party;	X
Prüfrechte	Pooled Audit und Tests, inkl. TLPT	Art. 8 Abs. 2 lit. b RTS TPPol	where appropriate, pooled audits and pooled ICT testing, including threat-led penetration testing, that are organised jointly with other contracting financial entities or firms that use ICT services of the same ICT third-party service provider and that are performed by those contracting financial entities or firms or by a third party appointed by them;	X
Prüfrechte	Zertifizierungen Dritter	Art. 8 Abs. 2 lit. c RTS TPPol	where appropriate, third-party certifications;	X
Prüfrechte	Prüfung durch die Interne Revision des IKT-Drittdienstleisters	Art. 8 Abs. 2 lit. d RTS TPPol	where appropriate, internal or third-party audit reports made available by the ICT third-party service provider.	X
Prüfrechte	Ausweitung des Prüfungs-/Zertifizierungsumfangs bei Verwendung von Zertifizierungen bzw. vom Dienstleister bereitgestellten Prüfungsberichten	Art. 8 Abs. 3 lit. g RTS TPPol	has the contractual right to request, with a frequency that is reasonable and legitimate from a risk management perspective, modifications of the scope of the certifications or audit reports to other relevant systems and controls;	X
Prüfrechte	Aufrechterhaltung von Prüfungsrechten bei Verwendung von Zertifizierungen bzw. vom Dienstleister bereitgestellten Prüfungsberichten	Art. 8 Abs. 3 lit. h RTS TPPol	has the contractual right to perform individual and pooled audits at its discretion with regard to the contractual arrangements and execute those rights in line with the agreed frequency.	X
Ausstieg	Ausstiegsstrategie mit Sicherstellung der durchgehenden Bereitstellung der Funktionen	Art. 30 Abs. 3 lit. f Ziffer i DORA	in dem der IKT-Drittdienstleister weiterhin die entsprechenden Funktionen oder IKT-Dienstleistungen bereitstellt, um das Risiko von Störungen im Finanzunternehmen zu verringern oder um dessen geordnete Abwicklung und Umstrukturierung sicherzustellen	X

Thema	Vertragsinhalt	Fundstelle	Auszug aus dem Rechtstext	kwF ¹³
Ausstieg	Ausstiegsstrategie mit adäquater Wechselmöglichkeit	Art. 30 Abs. 3 lit. f Ziffer ii DORA	der dem Finanzunternehmen ermöglicht, zu einem anderen IKT-Drittdienstleister zu wechseln oder auf interne Lösungen umzustellen, die der Komplexität der erbrachten Dienstleistung entsprechen.	X
Ausstieg	Ausstiegsstrategien und Festlegung eines verbindlichen angemessenen Übergangszeitraums	Art. 30 Abs. 3 lit. f DORA	Ausstiegsstrategien, insbesondere die Festlegung eines verbindlichen angemessenen Übergangszeitraums,	X
Aufsicht	Zusammenarbeit mit zuständigen Behörden	Art. 3 Abs. 8 lit. c RTS TPPol	The policy shall explicitly specify that the contractual arrangements: [...] are to require that the ICT third party service providers cooperate with the competent authorities;	X
Datenzugriff	Zugang zu Daten und Räumlichkeiten	Art. 3 Abs. 8 lit. d RTS TPPol	The policy shall explicitly specify that the contractual arrangements: [...] are to require that the financial entity, its auditors, and competent authorities have effective access to data and premises relating to the use of ICT services supporting critical or important functions.	X
Andere relevante Vertragsinhalte	Konkretisierung der relevanten Vertragsinhalte gemäß den Anforderungen aus Art. 1 Abs. 1 lit. a DORA und anderen relevanten Gesetzen	Art. 8 Abs. 1 RTS TPPol	The policy shall specify that the relevant contractual arrangement are to be in written form and are to include all the elements referred to in Article 30(2) and (3) of Regulation (EU) 2022/2554. The policy shall also include elements regarding requirements referred to in Article 1(1), point (a), of Regulation (EU) 2022/2554, as well as other relevant Union and national law as appropriate.	X
Andere relevante Vertragsinhalte - Risikomanagement	IKT-Risikomanagement	Art. 1 Abs. 1 lit. a Ziffer i DORA	[Ggf. geltende Anforderungen in Bezug auf] Risikomanagement im Bereich der Informations- und Kommunikationstechnologie (IKT);	X
Andere relevante Vertragsinhalte - IKT-Vorfall	Berichterstattung über wichtige IKT-bezogene Vorfälle	Art. 1 Abs. 1 lit. a Ziffer ii DORA	[Ggf. geltende Anforderungen in Bezug auf] Meldung schwerwiegender IKT-bezogener Vorfälle und — auf freiwilliger Basis — erheblicher Cyberbedrohungen an die zuständigen Behörden;	X
Andere relevante Vertragsinhalte - IKT-Vorfall	Berichterstattung über wichtige Zahlungsvorfälle	Art. 1 Abs. 1 lit. a Ziffer iii DORA	[Ggf. geltende Anforderungen in Bezug auf] Meldung schwerwiegender zahlungsbezogener Betriebs- oder Sicherheitsvorfälle durch in Art. 2 Absatz 1 Buchstaben a bis d aufgeführte Finanzunternehmen an die zuständigen Behörden;	X
Andere relevante Vertragsinhalte - DOR-Tests	DOR-Tests	Art. 1 Abs. 1 lit. a Ziffer iv DORA	[Ggf. geltende Anforderungen in Bezug auf] Tests der digitalen operationalen Resilienz;	X

Thema	Vertragsinhalt	Fundstelle	Auszug aus dem Rechtstext	kwF ¹³
Andere relevante Vertragsinhalte - Austausch von Cyber-Informationen	Austausch von Cyber-Informationen	Art. 1 Abs. 1 lit. a Ziffer v DORA	[Ggf. geltende Anforderungen in Bezug auf] Austausch von Informationen und Erkenntnissen in Bezug auf Cyberbedrohungen und Schwachstellen;	X
Andere relevante Vertragsinhalte - Risikomanagement	Drittparteienrisikomanagement	Art. 1 Abs. 1 lit. a Ziffer vi DORA	[Ggf. geltende Anforderungen in Bezug auf] Maßnahmen für das solide Management des IKT-Drittparteienrisikos;	X
Überwachung	Maßnahmen und Messgrößen („key indicators“) zur Überwachung der Leistungsfähigkeit, Anforderungen zur Informationssicherheit und der Richtlinien und Prozess des Finanzunternehmens	Art. 9 Abs. 1 RTS TPPol	The policy shall require that the contractual arrangements specify the measures and key indicators to monitor, on an ongoing basis, the performance of ICT third party service providers, including measures to monitor compliance with requirements regarding the confidentiality, availability, integrity and authenticity of data and information, and the compliance of the ICT third-party service providers with the financial entity's relevant policies and procedures. [...]	X
Überwachung	Maßnahmen für nicht hinreichende Dienstleistungsgüte	Art. 9 Abs. 1 RTS TPPol	[...] The policy shall also specify measures that apply when service level agreements are not met, including contractual penalties where appropriate.	X
Kündigung	Sicherstellung von vertraglichen Kündigungsrechten	Art. 28 Abs. 7 DORA	Finanzunternehmen stellen sicher, dass vertragliche Vereinbarungen über die Nutzung von IKT-Dienstleistungen gekündigt werden können, wenn einer der folgenden Umstände vorliegt:	
Kündigung	Kündigungsrecht bei erheblichem Verstoß gegen bestehende Regelungen	Art. 28 Abs. 7 lit. a DORA	ein erheblicher Verstoß des IKT-Drittdienstleisters gegen geltende Gesetze, sonstige Vorschriften oder Vertragsbedingungen;	
Kündigung	Kündigungsrecht bei der Feststellung von beeinträchtigenden Umständen	Art. 28 Abs. 7 lit. b DORA	Umstände, die im Laufe der Überwachung des IKT-Drittparteienrisikos festgestellt wurden und die als geeignet eingeschätzt werden, die Wahrnehmung der im Rahmen der vertraglichen Vereinbarung vorgesehenen Funktionen zu beeinträchtigen, einschließlich wesentlicher Änderungen, die sich auf die Vereinbarung oder die Verhältnisse des IKT-Drittdienstleisters auswirken;	
Kündigung	Kündigungsrecht bei Nachweis von Schwächen im IKT-Risikomanagement des IKT-Drittdienstleisters	Art. 28 Abs. 7 lit. c DORA	nachweisliche Schwächen des IKT-Drittdienstleisters in Bezug auf sein allgemeines IKT-Risikomanagement und insbesondere bei der Art und Weise, in der er die Verfügbarkeit, Authentizität, Sicherheit und Vertraulichkeit von Daten gewährleistet, unabhängig davon, ob es sich um personenbezogene oder anderweitig sensible Daten oder nicht personenbezogene Daten handelt;	

Thema	Vertragsinhalt	Fundstelle	Auszug aus dem Rechtstext	kwF ¹³
Kündigung	Kündigungsrecht bei Umständen, die eine wirksame Aufsicht der zuständigen Behörde verhindern	Art. 28 Abs. 7 lit. d DORA	die zuständige Behörde kann das Finanzunternehmen infolge der Bedingungen der jeweiligen vertraglichen Vereinbarung oder der mit dieser Vereinbarung verbundenen Umstände nicht mehr wirksam beaufsichtigen.	
Unterauftragsvergabe - Kündigung	Kündigungsrechte im Zusammenhang mit Unterauftragsvergabe	Art. 7 Abs. 1 RTS-E SUB	Without prejudice to the termination clauses set out in accordance with Article 28 paragraph (10) of Regulation (EU) 2022/2554, the financial entity has a right to terminate the agreement with the ICT third-party service provider in each of the following cases:	X
Unterauftragsvergabe - Kündigung	Kündigungsrecht bei nicht abgestimmten, wesentlichen Änderungen der Unterauftragsvergabe	Art. 7 Abs. 1 lit. a RTS-E SUB	when the ICT third-party service provider implements material changes to subcontracting arrangements despite the objection of the financial entity, or without approval within the notice period as referred to in Article 6,	X
Unterauftragsvergabe - Kündigung	Kündigungsrecht bei einer explizit nicht zulässigen Unterauftragsvergabe von kritischen oder wichtigen Funktionen	Art. 7 Abs. 1 lit. b RTS-E SUB	when the ICT third-party service provider subcontracts an ICT service supporting a critical or important function explicitly not permitted to be subcontracted by the contractual agreement.	X
Unterauftragsvergabe	Verpflichtung der Nachbildung der relevanten Vertragsinhalte bei Unterauftragsvergaben	Art. 3 Abs. 1 lit. c RTS-E SUB	that the relevant clauses of the contractual arrangements between the financial entity and the ICT third-party service provider are replicated as appropriate in the subcontracting arrangements between the ICT third-party service provider and its subcontractor to ensure that the financial entity is able to comply with its own obligations under Regulation (EU) 2022/2554;	X
Unterauftragsvergabe	Beschreibung und Bedingungen unter denen eine Unterauftragsvergabe zulässig ist	Art. 4 RTS-E SUB	When describing in the written contractual arrangements the ICT services to be provided by an ICT third-party service provider in accordance with Article 30(2)(a) of Regulation (EU) 2022/2554, financial entities shall identify which ICT services support critical or important functions and which of those are eligible for subcontracting and under which conditions. In particular, and without prejudice to the final responsibility of the financial entity, for each ICT service eligible for subcontracting the written contractual agreement shall specify:	X
Unterauftragsvergabe - Überwachung	Überwachungspflichten bzgl. der Unterauftragsvergabe kritischer oder wichtiger Funktionen	Art. 4 lit. a RTS-E SUB	that the ICT third-party service provider is required to monitor all subcontracted ICT services supporting a critical or important function to ensure that its contractual obligations with the financial entity are continuously met;	X

Thema	Vertragsinhalt	Fundstelle	Auszug aus dem Rechtstext	kwF ¹³
Unterauftragsvergabe - Überwachungs- und Meldepflichten	Überwachungs- und Meldepflichten ggü. dem Finanzunternehmen	Art. 4 lit. b RTS-E SUB	the monitoring and reporting obligations of the ICT third-party service provider towards the financial entity;	X
Unterauftragsvergabe - Risikobewertung	Bewertung aller Risiken (inkl. Standortbezogene IKT-Risiken)	Art. 4 lit. c RTS-E SUB	that the ICT third-party service provider shall assess all risks, including ICT risks, associated with the location of the potential subcontractor and its parent company and the location where the ICT service is provided from;	X
Unterauftragsvergabe - Standort	Datenverarbeitung und -speicherort von untervergebenen IKT-Dienstleistungen	Art. 4 lit. d RTS-E SUB	the location and ownership of data processed or stored by the subcontractor, where relevant;	X
Unterauftragsvergabe - Überwachungs- und Meldepflichten	Beschreibung der Überwachungs- und Meldepflichten des Unterauftragnehmers	Art. 4 lit. e RTS-E SUB	that the ICT third-party service provider is required to specify the monitoring and reporting obligations of the subcontractor towards the ICT third-party service provider, and where relevant, towards the financial entity;	X
Unterauftragsvergabe - Geschäftsfortführungsmanagement	Verpflichtung zur kontinuierlichen Leistungsbereitstellung	Art. 4 lit. f RTS-E SUB	that the ICT third-party service provider is required to ensure the continuous provision of the ICT services supporting critical or important functions, even in case of failure by a subcontractor to meet its service levels or any other contractual obligations;	X
Unterauftragsvergabe - Geschäftsfortführungsmanagement	Geschäftsfortführungsmanagement beim Unterauftragnehmer	Art. 4 lit. g RTS-E SUB	the incident response and business continuity plans in accordance with Article 11 of Regulation (EU) 2022/2554 and service levels to be met by the ICT subcontractors;	X
Unterauftragsvergabe - Sicherheit	IKT-Sicherheitsstandards beim Unterauftragnehmer	Art. 4 lit. h RTS-E SUB	the ICT security standards and any additional security features, where relevant, to be met by the subcontractors in line with the RTS mandated by Article 28(10) of Regulation (EU) 2022/2554;	X
Unterauftragsvergabe - Prüfrechte & Datenzugriff	Gewährung vergleichbarer Audit-, Informations- und Zugangsrechte	Art. 4 lit. i RTS-E SUB	that the subcontractor shall grant to the financial entity and relevant competent and resolution authorities at least the same audit, information and access rights as entity and relevant competent authorities by the ICT third-party service provider;	X
Unterauftragsvergabe - Kündigung	Kündigungsrechte bei Feststellung von beeinträchtigenden Umständen	Art. 4 lit. j RTS-E SUB	that the financial entity has termination rights in accordance with article 7, or in case the provision of services fails to meet service levels agreed by the financial entity.;	X

Thema	Vertragsinhalt	Fundstelle	Auszug aus dem Rechtstext	kwF ¹³
Unterauftragsvergabe - Mitteilungsfrist	Ausreichende Mitteilungsfrist bei wesentlichen Veränderungen bei Unterauftragsvergaben und Verpflichtung in dieser Frist keine Veränderungen zu vollziehen, sowie das Recht Änderungen zu verlangen	Art. 6 Abs. 1 RTS-E SUB	In case of any material changes to the subcontracting arrangements, the financial entity shall ensure, through the ICT contractual arrangement with its ICT third-party service provider, that it is informed with a sufficient advance notice period to assess the impact on the risks it is or might be exposed to, in particular where such changes might affect the ability of the ICT third-party service provider to meet its obligations under the contractual agreement, and with regard to changes considering the elements listed in Article 1.	X
Unterauftragsvergabe - Widerspruchsrecht	Keine Änderungen an der Unterauftragsvergabe während der Mitteilungsfrist oder ohne Zustimmung	Art. 6 Abs. 3 RTS-E SUB	The financial entity shall require that the ICT third-party service provider implements the material changes only after the financial entity has either approved or not objected to the changes by the end of the notice period.	X
Unterauftragsvergabe - Widerspruchsrecht	Recht Anpassungen an geplanten Änderungen der Unterauftragsvergabe zu verlangen	Art. 6 Abs. 4 RTS-E SUB	The financial entity shall have a right to request modifications to the proposed subcontracting changes before their implementation if the risk assessment referred to in paragraph 1) concludes that the planned subcontracting or changes to subcontracting by the ICT third-party service provider exposes the financial entity to risks as specified in Article 3(1) that exceed its risk appetite.	X